

Dispense complete di studio

Materiale per prova scritta e orale — Assistente informatico / statistico, Provincia autonoma di Trento.

13 argomenti · materiale punto per punto con glossario e suggerimenti d'esame.

Indice

1. CAD — Codice dell'Amministrazione Digitale (6 punti) — tecnico
2. Documento digitale e firme (5 punti) — tecnico
3. eIDAS 2.0 — identità, firme, PEC e SERCQ (5 punti) — tecnico
4. Acquisizione e riuso del software (linee guida AgID) (5 punti) — tecnico
5. Cloud — IaaS, PaaS, SaaS e PA (6 punti) — tecnico
6. Interoperabilità applicativa (6 punti) — tecnico
7. Database relazionali e SQL (7 punti) — tecnico
8. Reti e modello OSI (6 punti) — tecnico
9. Virtualizzazione: VM e container (6 punti) — tecnico
10. Sicurezza di base (utile a quiz e orale) (5 punti) — tecnico
11. Ordinamento statutario PAT (5 punti) — istituzionale
12. Anticorruzione e trasparenza (PIAO) (5 punti) — istituzionale
13. Codice di comportamento e disciplinare (5 punti) — istituzionale

CAD — Codice dell'Amministrazione Digitale

Il D.Lgs. 82/2005 è il telaio normativo della PA digitale: principi, destinatari, AgID, RTD e diritti di cittadinanza digitale.

Da ricordare

In risposta: norma (CAD) !' principio/diritto !' soggetto responsabile (AgID/RTD) !' effetto pratico per cittadino o ente.

1. Destinatari del CAD

Il CAD si applica innanzitutto alle pubbliche amministrazioni e, in misura differenziata, ad altri soggetti che erogano servizi pubblici.

Il Codice dell'Amministrazione Digitale (D.Lgs. 7 marzo 2005, n. 82) disciplina l'uso delle tecnologie dell'informazione e della comunicazione nei rapporti tra cittadini, imprese e pubblica amministrazione. Il nucleo dei destinatari è costituito dalle pubbliche amministrazioni, intese nel senso ampio dell'ordinamento nazionale: amministrazioni centrali, regioni, province autonome, comuni, università, enti pubblici non economici e altri organismi di diritto pubblico.

Molte disposizioni del CAD si estendono anche ai gestori di servizi pubblici e alle società controllate dalle PA, quando operano nell'ambito di attività di interesse generale. Non tutte le norme si applicano in modo uniforme: alcune obbligazioni (ad esempio su identità digitale, domicilio digitale o interoperabilità) possono avere un perimetro più ampio o più ristretto a seconda della disposizione concreta. In quiz, evita risposte assolute del tipo «vale solo per i Comuni».

In sede di concorso conviene ricordare che il CAD non è un regolamento tecnico di dettaglio, ma il quadro legislativo di riferimento: le linee guida AgID e i regolamenti europei (come eIDAS e GDPR sul piano privacy) lo completano e lo aggiornano. Per un assistente informatico della PAT è utile collegare sempre «chi deve applicare» (ente, RTD, fornitore) al «cosa» (diritto del cittadino, obbligo di digitalizzazione, riuso, conservazione).

Glossario

CAD — Codice dell'Amministrazione Digitale, D.Lgs. 82/2005, come modificato nel tempo.

Gestore di servizi pubblici — Soggetto che eroga servizi di interesse generale; molte norme CAD possono estendersi anche a lui.

In prova: Quiz e sintetiche: non limitarti a «vale per le PA». Specifica che molte disposizioni si estendono a gestori di servizi pubblici e società controllate, con ambito variabile a seconda della norma.

Riferimenti: D.Lgs. 82/2005 (CAD)

2. AgID — Agenzia per l'Italia Digitale

AgID è l'agenzia nazionale che emana linee guida, promuove standard e monitora la digitalizzazione della PA.

L'Agenzia per l'Italia Digitale (AgID) è il soggetto nazionale di riferimento per l'attuazione dell'agenda digitale e per il supporto alle pubbliche amministrazioni nell'uso delle ICT. Nel quadro del CAD, AgID adotta linee guida vincolanti o di indirizzo su temi come documento informatico, conservazione, accessibilità, riuso del software e interoperabilità.

Oltre all'emanazione di standard e cataloghi (ad esempio strumenti legati al riuso e all'interoperabilità), AgID svolge attività di monitoraggio e di supporto tecnico-organizzativo. Non sostituisce le responsabilità interne dell'ente: la digitalizzazione resta in capo all'amministrazione, con guida del RTD e collaborazione delle strutture IT.

Per la prova: se ti chiedono «chi definisce le regole tecniche» o «chi pubblica linee guida su riuso/documento digitale», la risposta tipica è AgID, nel rispetto del CAD e del diritto europeo. Distingui AgID (indirizzo digitale nazionale) da ACN (autorità per la cybersicurezza nazionale, rilevante per cloud e sicurezza) e dal Dipartimento per la trasformazione digitale (indirizzo politico-programmatico).

Glossario

Linee guida AgID — Atti di indirizzo/attuazione tecnica previsti dal CAD su documenti, riuso, accessibilità, interoperabilità, ecc.

In prova: Schema orale: AgID = linee guida + standard + monitoraggio. Non confonderla con ACN (cybersicurezza/cloud) né con il RTD (figura interna all'ente).

Riferimenti: D.Lgs. 82/2005 · Sito e linee guida AgID

3. RTD — Responsabile per la Transizione Digitale

Il RTD è la figura obbligatoria che guida digitalizzazione, interoperabilità e sicurezza ICT all'interno dell'ente.

Il Responsabile per la Transizione Digitale (RTD) è previsto dal CAD come punto di coordinamento interno della trasformazione digitale. Non è un «tecnico di secondo livello» generico: è il soggetto che assicura coerenza tra strategie digitali, piani di sviluppo ICT, interoperabilità dei sistemi e misure di sicurezza, in raccordo con i vertici dell'amministrazione.

Nella pratica il RTD promuove l'adozione dei servizi digitali, vigila sul rispetto delle regole su accessibilità e riuso, supporta i progetti di dematerializzazione e collabora con le strutture di cybersecurity e con i responsabili dei trattamenti. Può essere supportato da un ufficio per la transizione digitale; nei piccoli enti le funzioni possono essere organizzate in modo aggregato, ma la responsabilità resta individuata.

In una risposta da concorso collega RTD !' obblighi CAD !' effetti concreti (catalogo servizi digitali, riuso software, posta elettronica istituzionale, formazione del personale). Evita di attribuire al RTD compiti che spettano ad altre figure (es. RPCT per anticorruzione, DPO per privacy), pur riconoscendo la necessaria collaborazione.

Glossario

RTD — Responsabile per la Transizione Digitale: figura obbligatoria prevista dal CAD in ciascuna PA.

In prova: Domanda tipica: «Chi guida la digitalizzazione nell'ente?» !' RTD. Cita collaborazione con IT, sicurezza e privacy, ma non confondere i ruoli.

Riferimenti: D.Lgs. 82/2005, disposizioni su RTD

4. Diritti di cittadinanza digitale

Usare le tecnologie nei rapporti con la PA è un diritto: servizi online, identità digitale e domicilio digitale sono pilastri del CAD.

Il CAD riconosce ai cittadini e alle imprese diritti di cittadinanza digitale: il rapporto con la pubblica amministrazione deve poter avvenire in modalità telematica, senza che l'uso del digitale sia un favore discrezionale dell'ufficio. Ciò implica servizi accessibili online, informazioni chiare, possibilità di presentare istanze e ricevere comunicazioni per via elettronica.

Elementi ricorrenti nelle prove: identità digitale (SPID, CIE) per autenticarsi ai servizi; domicilio digitale (indirizzo elettronico eletto per le comunicazioni ufficiali); diritto di accedere ai propri dati e di non dover ripresentare informazioni già in possesso della PA (principio once-only, collegato all'interoperabilità). L'accessibilità dei siti e delle app è parte integrante di questi diritti, non un optional.

Per l'assistente informatico: i diritti digitali si traducono in requisiti di sistema (autenticazione, logging, usabilità, canali multipli inclusa app IO ove prevista) e in doveri organizzativi (tempi di risposta, qualità dei dati, formazione front-office). In risposta sintetica, elenca 3–4 diritti concreti e collega ciascuno a uno strumento tecnico.

Glossario

Domicilio digitale — Indirizzo elettronico (es. PEC) eletto per ricevere comunicazioni dalla PA con valore legale.

Identità digitale — Mezzo di identificazione elettronica (in Italia tipicamente SPID o CIE) per accedere ai servizi online.

In prova: Elenca diritti + strumento: accesso servizi online !' SPID/CIE; comunicazioni !' domicilio digitale/PEC; non ridare dati !' once-only.

Riferimenti: D.Lgs. 82/2005

5. Principi: digital first, once only, accessibilità, riuso

I principi del CAD orientano progettazione dei servizi: digitale per default, dati una sola volta, accessibilità e riuso del software.

Digital first (o «digitale per default») significa che i servizi devono essere progettati prioritariamente in modalità digitale, mantenendo canali alternativi per chi non può usarli, ma senza trattare il digitale come un'appendice del cartaceo. Once only: il cittadino o l'impresa non devono fornire più volte dati già detenuti dalla PA; l'ente li acquisisce tramite interoperabilità e basi dati di qualità.

Accessibilità: siti, documenti e applicazioni devono essere fruibili anche da persone con disabilità, secondo la normativa nazionale sull'accessibilità ICT e le linee guida AgID. Non è solo un tema «etico»: è un obbligo giuridico e un requisito di qualità del servizio pubblico. Sicurezza e trasparenza accompagnano questi principi: i servizi digitali devono proteggere dati e sistemi e rendere comprensibili processi e responsabilità.

Riuso e preferenza per soluzioni aperte: prima di acquistare o sviluppare ex novo, la PA valuta soluzioni già disponibili presso altre amministrazioni e, ove conveniente, software open source. In sede d'esame, presenta i principi come criteri decisionali (come si progetta un servizio?) e non come slogan: per ciascuno indica un effetto operativo (API, catalogo riuso, checklist accessibilità, SPID obbligatorio sui servizi, ecc.).

Glossario

Digital first — Progettazione prioritaria dei servizi in modalità digitale.

Once only — Il cittadino non ridà dati già in possesso della PA; serve interoperabilità.

In prova: In sintetica: elenca 4 principi con una riga di effetto pratico ciascuno. Once-only " backup; riuso " obbligo di usare sempre gratis/open source senza valutazione.

Riferimenti: D.Lgs. 82/2005 · Linee guida AgID su accessibilità e riuso

6. Istanze e comunicazioni telematiche

Il CAD indica i canali ammessi per presentare istanze alla PA: PEC, identità digitale, app IO, portali e altri strumenti riconosciuti.

Le istanze, le dichiarazioni e le comunicazioni verso la pubblica amministrazione possono (e spesso devono) essere presentate in modalità telematica attraverso i canali previsti dal CAD e dalle regole attuative. Tra gli strumenti tipici: posta elettronica certificata, autenticazione con SPID o CIE sui portali istituzionali, app IO e sportelli digitali dell'ente.

Il valore della presentazione telematica dipende dal rispetto delle regole su identificazione del mittente, integrità del contenuto e, ove richiesto, sottoscrizione con firma elettronica adeguata. Non basta «inviare una mail ordinaria»: l'ufficio deve poter accertare provenienza e completezza dell'istanza secondo le procedure interne e la normativa vigente.

Operativamente, l'assistente informatico supporta la configurazione dei canali (integrazione SPID/CIE, caselle PEC istituzionali, protocollazione automatica, monitoraggio disponibilità). In prova, cita almeno tre canali e spiega perché la PEC ha valore di raccomandata per la trasmissione, mentre la firma elettronica attiene alla sottoscrizione del contenuto.

Glossario

App IO — Applicazione nazionale per messaggi e servizi digitali della PA verso il cittadino.

In prova: Distingui sempre canale di trasmissione (PEC, portale) da firma sul documento. Elenca PEC, SPID/CIE, app IO come esempi da CAD.

Riferimenti: D.Lgs. 82/2005

Documento digitale e firme

Documento informatico, validità, conservazione e scala delle firme elettroniche (eIDAS / CAD).

Da ricordare

Non confondere trasmissione (PEC) con sottoscrizione (firma). Per confidenzialità cifrare con chiave pubblica del destinatario; per autenticità firmare con chiave privata del mittente.

1. Documento informatico

È la rappresentazione informatica di atti, fatti o dati giuridicamente rilevanti; può essere nato digitale o digitalizzato.

Secondo il quadro CAD/eIDAS, il documento informatico è la rappresentazione informatica di atti, fatti o dati giuridicamente rilevanti. Può essere creato nativamente in formato elettronico (born digital) oppure derivare dalla digitalizzazione di un originale analogico. Formato (PDF/A, XML, formati aperti), metadati e processo di formazione determinano qualità, ricercabilità e utilizzabilità nel tempo: un file «orfano» di contesto perde valore amministrativo anche se tecnicamente integro.

Nella PA il documento informatico è alla base di protocollo informatico, fascicolo digitale e procedimenti interamente telematici. Non basta «avere un PDF»: servono regole su chi lo forma, come lo identifica univocamente, come lo rende immutabile dopo la chiusura e come lo rende ricercabile (metadati di protocollo, classificazione, riferimenti al procedimento, versione). Le linee guida AgID sul documento informatico orientano formazione, gestione e conservazione in modo coerente su tutto il ciclo di vita.

In sede d'esame definisci il concetto, poi distingui documento informatico (contenuto giuridicamente rilevante) da supporto fisico/logico, canale di trasmissione (PEC, portale) e firma (sottoscrizione). Un esempio concreto da Assistente informatico: determina dirigenziale firmata digitalmente, protocollata e conservata a norma — tre piani diversi ma collegati. Chiudi ricordando che la scansione senza processo documentale non «crea» automaticamente un originale digitale a tutti gli effetti.

Glossario

Documento informatico — Rappresentazione informatica di atti, fatti o dati giuridicamente rilevanti.

Metadati — Dati che descrivono il documento (autore, data, protocollo, classifica) essenziali per gestione e conservazione.

In prova: Apri con la definizione, poi cita formazione + metadati + collegamento a protocollo/conservazione.

Riferimenti: D.Lgs. 82/2005 · Linee guida AgID sul documento informatico

2. Valore probatorio

Il valore probatorio del documento informatico cresce con firme, procedure di formazione e conservazione a norma.

Il documento informatico ha efficacia probatoria che dipende dalle modalità di formazione, sottoscrizione e conservazione. In sintesi didattica: un file privo di firme e di controlli ha un'efficacia più limitata; l'apposizione di firme elettroniche (soprattutto qualificata/digitale) e l'uso di processi certificati aumentano l'opponibilità a terzi e la resistenza a contestazioni di autenticità o integrità. Il giudice valuta caso per caso, ma in sede amministrativa si lavora per massimizzare le garanzie.

Il CAD e il regolamento eIDAS fissano il quadro: non inventare «gradi» numerici non previsti dalla norma, ma spiega la scala qualitativa (semplice !' avanzata !' qualificata) e il ruolo delle procedure organizzative (chi ha firmato, con quale certificato, in quale sistema, con quali log di audit). Anche la marca temporale rafforza la data certa del documento, utile quando conta dimostrare l'esistenza di un contenuto in un istante preciso.

Per una risposta sintetica: «Il valore probatorio non è automatico solo perché il file è digitale; dipende da firma, identificazione del firmatario, integrità e conservazione.» Aggiungi un esempio PA (atto amministrativo firmato digitalmente e conservato a norma vs bozza di lavoro su file share). Per l'assistente informatico: strumenti di verifica firma, gestione certificati e policy di conservazione sono parte del valore probatorio operativo.

Glossario

Valore probatorio — Capacità del documento di dimostrare fatti o atti in giudizio o in procedimento, variabile con firme e processi.

Marca temporale — Attestazione di data e ora certe associate a un documento elettronico.

In prova: Evita formule assolute («il PDF vale sempre come l'atto cartaceo»). Motiva con firma + processo + conservazione.

Riferimenti: D.Lgs. 82/2005 · Regolamento eIDAS

3. Scala delle firme (eIDAS / firma digitale)

Firma elettronica semplice < avanzata < qualificata; la firma digitale italiana è tipicamente una FEQ basata su crittografia asimmetrica e certificato.

Il regolamento eIDAS classifica le firme elettroniche in semplice, avanzata e qualificata. La firma elettronica semplice è un insieme di dati elettronici collegati o associati al documento (es. scansione di firma, checkbox «accetto»); offre garanzie limitate sull'identità e sull'integrità. La firma avanzata è connessa univocamente al firmatario, lo identifica, è creata con dati di creazione sotto il suo controllo esclusivo e consente di rilevare modifiche successive al documento.

La firma elettronica qualificata (FEQ) è una firma avanzata creata con un dispositivo per la creazione di firme qualificato e basata su un certificato qualificato: ha l'effetto giuridico equivalente della firma autografa, nei limiti dell'ordinamento. In Italia la «firma digitale» è la tipica implementazione di FEQ basata su crittografia asimmetrica e certificato rilasciato da un prestatore di servizi fiduciari qualificato (QTSP), spesso con smart card, token o HSM in cloud signing.

In prova ricorda la scala e un esempio d'uso PA: atti che richiedono sottoscrizione «forte» (determinazioni, contratti, provvedimenti) usano firma digitale/FEQ; operazioni a basso rischio possono basarsi su autenticazione SPID e accettazione elettronica secondo le regole del servizio. Distingui firma (persona fisica) da sigillo elettronico (tipicamente persona giuridica) e da autenticazione (SPID/CIE non firmano il PDF da sole).

Glossario

FEQ — Firma elettronica qualificata: livello più elevato previsto da eIDAS, equivalente alla firma autografa.

Firma digitale — Nel linguaggio italiano CAD, tipicamente FEQ basata su chiavi asimmetriche e certificato.

Dispositivo qualificato — Strumento (token, smart card, HSM) che crea firme qualificate sotto controllo del firmatario.

In prova: Memorizza la scala eIDAS e la frase: firma digitale italiana "H FEQ. Non confondere con SPID (identificazione) o PEC (trasmissione).

Riferimenti: Regolamento eIDAS · D.Lgs. 82/2005

4. PEC vs firma

La PEC prova l'invio/ricezione con valore di raccomandata; non firma da sola il contenuto del messaggio.

La Posta Elettronica Certificata fornisce al mittente e al destinatario ricevute che attestano l'avvenuta spedizione e consegna (e, nei casi previsti, di accettazione/mancata consegna), con effetti equiparati alla raccomandata secondo la normativa. Garantisce quindi un servizio di recapito elettronico certificato sul piano della trasmissione, con log e ricevute opponibili, fondamentale per notifiche e istanze verso la PA.

La PEC non equivale automaticamente a una firma elettronica qualificata sul contenuto allegato: un messaggio PEC può trasportare un documento non firmato, oppure un documento già firmato digitalmente. Sono piani distinti: trasmissione vs sottoscrizione. Per riservatezza del contenuto occorre inoltre cifrare; la PEC di per sé non implica cifratura end-to-end del payload, anche se il canale verso i gestori è protetto.

In risposta d'esame usa una tabella mentale: PEC !' «quando/come è stato inviato e consegnato»; firma digitale !' «chi ha sottoscritto e se il file è integro»; SPID !' «chi si è autenticato al servizio». L'evoluzione europea (SERCQ / recapito elettronico certificato qualificato) mira ad armonizzare i servizi di recapito oltre il modello PEC nazionale, senza che in prova si debbano inventare date di «abolizione» della PEC.

Glossario

PEC — Posta Elettronica Certificata: servizio di recapito con ricevute aventi valore legale di raccomandata.

Ricevuta di avvenuta consegna — Messaggio di sistema PEC che attesta la consegna nella casella del destinatario.

In prova: Trappola tipica del quiz: «La PEC firma il documento» !' falso. PEC = trasmissione certificata; firma = sottoscrizione.

Riferimenti: D.Lgs. 82/2005 · eIDAS (servizi di recapito elettronico certificato)

5. Conservazione a norma

Conservare a norma significa garantire nel tempo integrità, leggibilità, reperibilità e metadati, con responsabilità del titolare.

La conservazione dei documenti informatici non è un semplice backup su disco o cloud. Il processo di conservazione a norma (secondo CAD e linee guida AgID) deve assicurare che il documento resti integro, leggibile, autenticabile e reperibile per tutto il periodo previsto dal piano di fascicolazione e dalle norme di settore (fiscale, sanitario, amministrativo). Serve un sistema documentale con ruoli, policy e controlli, non solo spazio di archiviazione.

Elementi tipici: pacchetto di versamento e di archiviazione con documento e metadati; riferimenti temporali; funzioni di esibizione; misure contro obsolescenza dei formati (migrazione controllata); affidamento a un conservatore (interno o esterno) secondo regole contrattuali e tecniche. Il titolare dell'oggetto di conservazione resta responsabile della scelta del modello e del rispetto dei requisiti, anche se delega operative a un fornitore.

Per l'assistente informatico: distinguere storage (disco/cloud), backup (ripristino operativo RPO/RTO) e conservazione a norma (valore giuridico-documentale nel tempo). In sintetica cita integrità + leggibilità + metadati + responsabilità del titolare/conservatore. Un restore da backup non «certifica» da solo la conformità documentale se manca il processo di conservazione.

Glossario

Conservazione a norma — Processo che mantiene nel tempo caratteristiche di integrità e leggibilità del documento informatico con metadati adeguati.

Pacchetto di archiviazione — Insieme di documenti, metadati e evidenze gestito nel sistema di conservazione.

In prova: Non dire «backup = conservazione». Elenca requisiti (integrità, leggibilità, metadati) e il ruolo del titolare/conservatore.

Riferimenti: D.Lgs. 82/2005 · Linee guida AgID sulla conservazione

eIDAS 2.0 — identità, firme, PEC e SERCQ

Il regolamento eIDAS (e aggiornamento 2.0) armonizza identità digitali e servizi fiduciari in UE.

Da ricordare

Collega sempre mezzo di identificazione (SPID/CIE) !' livello di garanzia !' servizio fiduciario (firma/PEC/SERCQ).

1. SPID, CIE e livelli di garanzia

SPID e CIE sono i principali mezzi di identificazione elettronica in Italia; eIDAS distingue livelli di garanzia basso, significativo e alto.

SPID (Sistema Pubblico di Identità Digitale) e CIE (Carta d'Identità Elettronica) consentono di autenticarsi ai servizi online della PA e, in molti casi, anche a servizi privati aderenti. Non sono firme sul documento: sono strumenti di identificazione elettronica. L'ente che espone un servizio decide quale livello di garanzia richiedere in base al rischio del procedimento (accesso a dati anagrafici vs disposizione di un atto ad alto impatto). Per l'assistente informatico: integrazione IdP/SP, metadati SAML/OIDC e test dei flussi di login sono attività quotidiane.

Il regolamento eIDAS classifica i mezzi di identificazione elettronica in livelli di garanzia (LoA — Level of Assurance): basso, significativo e alto. Il livello cresce con la robustezza delle procedure di riconoscimento iniziale (enrollment), di autenticazione (uno o più fattori) e di gestione delle credenziali (revoca, recupero, protezione anti-furto). In pratica, operazioni sensibili (dati sanitari, pagamenti, atti con effetti giuridici rilevanti) richiedono livelli più elevati; servizi informativi possono accontentarsi di livelli inferiori.

In risposta da concorso: definisci SPID/CIE, spiega i tre LoA, fai un esempio («servizio a rischio contenuto !' LoA significativo; dati critici !' livello alto»). Distingui chiaramente identificazione (chi è l'utente) da firma (sottoscrizione del contenuto) e da PEC (recapito). Ricorda che l'interoperabilità cross-border europea si baserà sempre più su schemi notificati e sul wallet EUDI, oltre agli strumenti nazionali già noti.

Glossario

LoA — Level of Assurance: livello di garanzia dell'identità elettronica (basso, significativo, alto).

SPID — Sistema Pubblico di Identità Digitale italiano.

CIE — Carta d'Identità Elettronica, utilizzabile anche come strumento di autenticazione.

In prova: Quiz: SPID/CIE = identificazione, non firma. Cita i tre LoA e il legame rischio del servizio !' livello richiesto.

Riferimenti: Regolamento eIDAS · CAD

2. Firme elettroniche e sigilli

eIDAS armonizza requisiti giuridici e tecnici di firme e sigilli elettronici in tutta l'UE.

Oltre alle firme delle persone fisiche, eIDAS disciplina i sigilli elettronici, tipicamente utilizzati dalle persone giuridiche (enti, imprese) per garantire origine e integrità di documenti o dati prodotti dall'organizzazione. Anche i sigilli seguono una logica di livelli (semplice, avanzato, qualificato) analoga a quella delle firme: il sigillo qualificato offre le garanzie più elevate e il riconoscimento europeo.

L'armonizzazione europea consente il riconoscimento reciproco delle firme e dei sigilli qualificati tra Stati membri, riducendo barriere al mercato unico digitale e agli scambi documentali transfrontalieri. Per la PA italiana restano rilevanti le regole CAD sulla formazione degli atti e l'uso della firma digitale nei procedimenti amministrativi: eIDAS non «cancella» il CAD, lo completa sul piano europeo.

In prova distingue con chiarezza: firma (persona fisica che sottoscrive) vs sigillo (soggetto giuridico che attesta origine/integrità); autenticazione (SPID/CIE) vs sottoscrizione; marca temporale (data/ora certe) vs firma. Uno schema chiaro batte elenchi confusi di prodotti commerciali o vendor. Esempio: un ente può apporre un sigillo su un estratto rilasciato dal sistema, mentre il dirigente firma digitalmente la determinazione.

Glossario

Sigillo elettronico — Dati elettronici legati a un documento per garantirne origine e integrità, tipicamente di una persona giuridica.

Sigillo qualificato — Sigillo elettronico di livello più elevato, con effetti rafforzati e riconoscimento UE.

In prova: Se chiedono «equivalente firma autografa» !' firma elettronica qualificata. Sigillo "" firma personale.

Riferimenti: Regolamento eIDAS · D.Lgs. 82/2005

3. Servizi fiduciari

Certificati, marca temporale, PEC/recapito certificato: servizi fiduciari regolati da eIDAS e vigilati a livello nazionale.

I servizi fiduciari (trust services) includono, tra gli altri, il rilascio di certificati qualificati per firme e sigilli, la validazione delle firme, la marca temporale qualificata e i servizi di recapito elettronico certificato. I prestatori qualificati (QTSP) devono rispettare requisiti stringenti di sicurezza, trasparenza, continuità operativa e audit periodici; figurano in elenchi di fiducia (trust lists) europei consultabili.

Per l'amministrazione, scegliere un prestatore qualificato significa potersi avvalere di effetti giuridici rafforzati e di riconoscibilità europea dei certificati e delle firme. L'ente resta comunque responsabile di configurare correttamente i processi interni: chi può firmare, come si conservano le evidenze, come si gestiscono scadenze e revoca dei certificati, come si verifica la firma in ingresso.

Risposta tipica da concorso: elenca almeno tre servizi fiduciari concreti (certificati di firma/sigillo, timestamp, PEC/SERCQ) e collega ciascuno a un bisogno amministrativo (sottoscrizione atti, data certa su un allegato, notifiche con prova di consegna). Non ridurre eIDAS alle sole «firme digitali» commerciali.

Glossario

Marca temporale — Servizio che associa data e ora certe a un documento elettronico.

QTSP — Qualified Trust Service Provider: prestatore di servizi fiduciari qualificati.

Trust list — Elenco ufficiale europeo dei prestatori e servizi fiduciari qualificati.

In prova: Non ridurre eIDAS alle sole firme: cita almeno certificati, timestamp e recapito certificato.

Riferimenti: Regolamento eIDAS

4. SERCQ — recapito elettronico certificato qualificato

Il SERCQ è il servizio europeo di recapito elettronico certificato qualificato: evoluzione/armonizzazione rispetto alla sola PEC nazionale.

Il Servizio Elettronico di Recapito Certificato Qualificato (SERCQ) rientra nei servizi fiduciari di recapito previsti da eIDAS. L'obiettivo è garantire, con requisiti europei comuni, prove di invio e consegna elettronica opponibili, superando la frammentazione tra soluzioni solo nazionali che ostacolano comunicazioni cross-border tra cittadini, imprese e PA di Stati membri diversi.

In Italia la PEC ha storicamente svolto il ruolo di strumento di recapito certificato nei rapporti con la PA e tra professionisti. Il percorso eIDAS 2.0 spinge verso interoperabilità e riconoscibilità pan-europea: il SERCQ si colloca in questa linea evolutiva. In sede d'esame non inventare date di «abolizione» della PEC non richieste dal quesito: conta capire la funzione (recapito certificato) e il piano europeo di armonizzazione.

Per una sintetica: definisci SERCQ, collegalo a eIDAS, confrontalo con la PEC (stessa funzione di fondo: prove di invio/consegna; piano diverso dalla firma digitale). Se chiedono «evoluzione europea della PEC» o «recapito certificato qualificato», SERCQ è la parola chiave. Ricorda: senza cifratura aggiuntiva, recapito certificato "non" confidenzialità del contenuto.

Glossario

SERCQ — Servizio Elettronico di Recapito Certificato Qualificato secondo il quadro eIDAS.

Recapito elettronico certificato — Servizio che fornisce evidenze di invio e/o consegna di un messaggio elettronico.

In prova: Associa SERCQ a recapito certificato europeo. Non dirlo sinonimo di firma digitale.

Riferimenti: Regolamento eIDAS (aggiornamento 2.0)

5. Wallet europeo di identità digitale (EUDI)

eIDAS 2.0 punta al portafoglio europeo di identità digitale per credenziali e attributi verificabili sotto controllo dell'utente.

Il European Digital Identity Wallet (EUDI Wallet) è l'elemento centrale dell'aggiornamento eIDAS 2.0: un'applicazione (o insieme di componenti) che consente al cittadino di conservare e presentare in modo selettivo attributi di identità e altre credenziali verificabili (titoli di studio, mandati, attestazioni, attributi anagrafici) rilasciate da soggetti pubblici o privati autorizzati, senza dover ridare ogni volta l'intero set di dati.

Il modello punta a privacy (divulgazione minima / selective disclosure), riconoscimento pan-europeo e uso sia verso la PA sia verso operatori privati obbligati o aderenti (banche, telecomunicazioni, grandi piattaforme nei casi previsti). Non sostituisce immediatamente SPID/CIE nel discorso d'esame, ma li colloca in una traiettoria di convergenza verso un ecosistema europeo di identità e attributi.

In risposta: spiega cos'è il wallet, perché serve (mobilità UE, once-only, controllo utente, riduzione di copie di documenti), e collega a LoA e servizi fiduciari. Evita dettagli di prodotto commerciali o roadmap inventate. Una chiusura efficace: «eIDAS 2.0 = identità e attestazioni portabili sotto controllo del cittadino, interoperabili in UE».

Glossario

EUDI Wallet — Portafoglio europeo di identità digitale previsto da eIDAS 2.0 per credenziali verificabili.

Selective disclosure — Possibilità di rivelare solo gli attributi necessari a uno specifico servizio, non l'intera identità.

In prova: Parola chiave d'esame per eIDAS 2.0: wallet EUDI + attributi verificabili + controllo dell'utente.

Riferimenti: Regolamento eIDAS 2.0

Acquisizione e riuso del software (linee guida AgID)

Prima di comprare o sviluppare, la PA deve valutare riuso e open source secondo CAD e linee guida AgID.

Da ricordare

Schema risposta: obbligo di valutazione !' catalogo riuso !' licenza !' rischio lock-in !' misura di mitigazione.

1. Obbligo di valutazione del riuso

Prima di un nuovo sviluppo o acquisto, la PA deve verificare se esistono soluzioni riusabili già disponibili nella pubblica amministrazione.

Il CAD e le linee guida AgID sull'acquisizione e il riuso del software impongono alle amministrazioni di valutare prioritariamente soluzioni già realizzate da altre PA e messe a riuso. L'obiettivo è ridurre costi, tempi e frammentazione applicativa, valorizzando investimenti pubblici già effettuati e favorendo interoperabilità tra enti che condividono gli stessi processi.

La valutazione non è un adempimento formale vuoto: va documentata (assessment), confrontando requisiti funzionali e non funzionali, costi di adattamento, sicurezza, sostenibilità manutentiva, competenze interne e vincoli di licenza. Solo se il riuso non è conveniente o non è disponibile una soluzione adeguata si procede verso open source di mercato, sviluppo o procurement tradizionale, secondo le priorità indicate dalle linee guida.

In prova: apri con l'obbligo di valutazione, cita il catalogo del riuso / Developers Italia come strumento di ricerca, e spiega che «valutare» non significa «usare sempre il riuso anche se inadatto», ma motivare la scelta in modo trasparente. Per l'assistente informatico: saper cercare nel catalogo, leggere README e licenza, stimare lo sforzo di adattamento è competenza operativa da citare.

Glossario

Catalogo del riuso — Strumento (ecosistema Developers Italia / AgID) per trovare software della PA disponibile al riuso.

Assessment — Valutazione documentata di riuso/OS/acquisto/sviluppo prima di procedere.

In prova: Parola d'ordine: assessment documentato prima di build/buy. Cita CAD + linee guida AgID.

Riferimenti: D.Lgs. 82/2005 · Linee guida AgID acquisizione e riuso software PA

2. Open source nella PA

Quando economicamente e tecnicamente conveniente, la PA preferisce software open source; non è un dogma senza valutazione.

Il software open source rende disponibili codice sorgente e diritti di studio, modifica e redistribuzione secondo i termini di licenza. Per la PA ciò favorisce auditabilità (si può ispezionare cosa fa il programma), indipendenza dal fornitore, possibilità di collaborare tra enti sullo stesso prodotto e maggiore facilità di exit rispetto a soluzioni completamente chiuse.

Le linee guida AgID indicano una preferenza per l'open source quando conviene: vanno comunque valutati supporto commerciale o comunitario, sicurezza della supply chain (dipendenze, CVE), competenze interne e total cost of ownership (TCO) su più anni. Un prodotto open source senza manutenzione, patch né documentazione può essere peggiore di una soluzione riusata e supportata da un'altra PA.

In risposta d'esame bilancia: vantaggi (trasparenza, riuso, exit, collaborazione) + doveri (valutazione, patching, governance delle modifiche, scelta della licenza in uscita). Evita slogan «open source = gratis» o «open source = sempre più sicuro»: la sicurezza dipende da processo e aggiornamenti, non dal solo modello di licenza.

Glossario

Open source — Software con sorgente disponibile e diritti di uso/modifica/redistribuzione secondo licenza OSI.

TCO — Total Cost of Ownership: costo complessivo di acquisizione, gestione e uscita nel tempo.

In prova: Preferenza "" obbligo assoluto. Motiva con costi, sicurezza e sostenibilità.

Riferimenti: Linee guida AgID acquisizione e riuso

3. Modelli di licenza

Copyleft (GPL), permissive (MIT, Apache) e proprietarie impattano obblighi di condivisione e possibilità di riuso.

Le licenze permissive (MIT, BSD, Apache 2.0) consentono ampio riuso, anche in prodotti proprietari, di solito con pochi obblighi (attribuzione, notice, a volte patent grant come in Apache). Le licenze copyleft forti (es. GPL) richiedono che le opere derivate redistribuite restino sotto la stessa licenza, «contagiando» il codice collegato secondo le regole della licenza; esistono anche copyleft «deboli» (LGPL, MPL) con effetti più circoscritti.

Le licenze proprietarie limitano uso, modifica e redistribuzione secondo il contratto: tipiche del software commerciale chiuso. Nella PA la scelta della licenza in uscita (quando si pubblica a riuso) e l'analisi delle licenze in ingresso (quando si integra codice di terzi) sono momenti critici di compliance: mischiare GPL e codice proprietario senza regole chiare genera rischi legali.

Per il concorso: sappi spiegare copyleft vs permissive con un esempio concreto (GPL vs MIT) e il rischio di incompatibilità tra licenze in un medesimo prodotto. Non serve citare articoli inventati: basta il ragionamento corretto su obblighi di condivisione, attribuzione e Redistribuzione. Collega alla pubblicazione a riuso con licenza chiara su Developers Italia.

Glossario

Copyleft — Modello (es. GPL) che impone di redistribuire le modifiche sotto la stessa licenza aperta.

Licenza permissiva — Modello (MIT, Apache) con obblighi minimi, ampia libertà di riuso.

In prova: Domanda tipica: differenza GPL vs MIT. Rispondi con obblighi di condivisione delle derivate.

Riferimenti: Linee guida AgID · Prassi Developers Italia

4. Vendor lock-in

Il lock-in è la dipendenza da fornitore o formato che rende costosa l'uscita; si mitiga con standard aperti e portabilità.

Il vendor lock-in si verifica quando costi di cambiamento, formati chiusi, API proprietarie, competenze rare o clausole contrattuali rendono difficile sostituire un fornitore senza interrompere il servizio. Nella PA il lock-in riduce concorrenza nei rinnovi, aumenta i costi di lungo periodo e può ostacolare interoperabilità, riuso e adempimenti di trasparenza.

Mitigazioni concrete: adozione di standard aperti e formati documentali aperti; proprietà o escrow del codice ove appropriato; clausole di exit e di portabilità dei dati nei contratti; architetture a componenti sostituibili (API, container); preferenza per soluzioni riusabili/open source valutate. Anche nel cloud occorre distinguere portabilità dei dati (export) da portabilità delle applicazioni (riscrittura su servizi PaaS proprietari).

Schema da esame: definizione !' esempio (formato chiuso, database proprietario, SaaS senza export) !' tre misure di mitigazione. Collega al principio di riuso, alle linee guida AgID e alla shared responsibility: uscire da un fornitore richiede pianificazione, non solo «buona volontà» a fine contratto.

Glossario

Lock-in — Dipendenza strutturale da un fornitore o tecnologia che rende onerosa la migrazione.

Exit strategy — Piano contrattuale e tecnico per abbandonare un fornitore portando dati e, ove possibile, applicazioni.

In prova: Sempre abbinare lock-in a mitigazione (standard aperti, exit strategy, portabilità dati).

Riferimenti: Linee guida AgID acquisizione e riuso

5. Flusso assessment !' riuso !' sviluppo !' pubblicazione

Il ciclo virtuoso AgID: valutare, riusare o sviluppare, poi pubblicare il risultato a riuso per altre PA.

Il flusso tipico indicato dalle linee guida può essere riassunto così: (1) assessment dei fabbisogni e ricerca nel catalogo del riuso / open source; (2) riuso o adozione OS se conveniente; (3) se necessario, sviluppo o acquisizione motivata, con attenzione a riusabilità fin dalla progettazione; (4) rilascio della soluzione a riuso con documentazione, codice, licenza adeguati e indicazioni di manutenzione.

La pubblicazione a riuso non è un «optional di fine progetto»: è parte del ritorno dell'investimento pubblico. Servono repository curati, istruzioni di installazione, contatti di manutenzione, changelog e chiarezza su cosa è riusabile «as-is» e cosa richiede adattamento locale (integrazioni anagrafiche, SSO, branding). Senza documentazione il codice pubblicato è di fatto inutilizzabile.

In sintetica usa i quattro passi in ordine e evidenzia che lo sviluppo ex novo arriva dopo la valutazione. Se ti chiedono cosa manca spesso nella realtà, cita documentazione, test, governance della manutenzione post-rilascio e aggiornamento della scheda nel catalogo. Per l'assistente IT: saper contribuire a README, issue e deploy è valore concreto.

Glossario

Riuso — Utilizzo da parte di una PA di software già realizzato da un'altra amministrazione.

Developers Italia — Ecosistema nazionale (catalogo, community) per software pubblico e riuso.

In prova: Rispondi con la pipeline in 4 stadi; evidenzia che lo sviluppo ex novo arriva dopo la valutazione.

Riferimenti: Linee guida AgID acquisizione e riuso

Cloud — IaaS, PaaS, SaaS e PA

Modelli di erogazione e responsabilità condivisa; per la PA anche qualificazione ACN e Polo Strategico Nazionale.

Da ricordare

In SaaS la patch dell'infrastruttura NON è in capo all'amministrazione utente. Chiediti sempre: cosa gestisco io?

1. IaaS — Infrastructure as a Service

L'ente ottiene compute, storage e rete virtuali e gestisce sistemi operativi, middleware e applicativi.

Nel modello IaaS il cloud provider eroga risorse infrastrutturali virtualizzate: macchine virtuali, volumi di storage, reti virtuali, bilanciatori di base. L'amministrazione installa e patcha il sistema operativo, configura runtime/middleware e applica le policy di sicurezza a livello di guest (hardening, antivirus, agent di monitoraggio). Il provider gestisce facility, hardware e strato di virtualizzazione.

È il modello più vicino al datacenter tradizionale «affittato»: massima flessibilità su stack e rete, ma anche maggiori responsabilità operative sull'ente o sul suo fornitore di managed services. Utile per carichi custom, legacy, appliance virtuali o quando serve controllo fine su sistemi operativi e segmentazione di rete.

In esame: elenca cosa gestisce il provider (hardware, hypervisor, facility) e cosa resta all'ente (OS, app, dati, identity degli admin, backup delle VM se non incluso). Collega sempre a shared responsibility: «chi patcha cosa» è la domanda chiave. Domanda classica: in IaaS puro la patch del SO guest è dell'amministrazione.

Glossario

IaaS — Infrastructure as a Service: infrastruttura virtuale self-service.

Shared responsibility — Riparto dei doveri di sicurezza tra provider cloud e amministrazione cliente.

In prova: Domanda classica: «Chi patcha il sistema operativo in IaaS?» !' l'amministrazione (o chi opera per lei), non il provider di sola IaaS.

Riferimenti: Strategia Cloud PA

2. PaaS — Platform as a Service

La piattaforma (runtime, DB gestiti, toolchain) è del provider; l'ente gestisce codice, configurazione applicativa e dati.

Il PaaS offre un ambiente pronto per sviluppare ed eseguire applicazioni: runtime, middleware, spesso database gestiti, code, storage object e strumenti CI/CD. L'amministrazione si concentra sul codice e sulla logica di business, senza amministrare hypervisor o, in molti casi, il sistema operativo sottostante, che resta in carico al provider.

Vantaggi: time-to-market, scaling facilitato, meno burden infrastrutturale, patch del runtime spesso gestite dal fornitore. Rischi: lock-in su servizi proprietari della piattaforma, vincoli su linguaggi/runtime, necessità di progettare portabilità, osservabilità e export dei dati. La responsabilità sui dati personali e sull'applicazione resta dell'ente titolare.

Confronto utile in prova: IaaS = controlli OS; PaaS = controlli app/dati; SaaS = controlli su uso e configurazione funzionale. Se chiedono «non gestisco il SO ma carico il codice e configuro il DB gestito» !' PaaS. Cita un esempio tipico (app web su runtime gestito + database as a service).

Glossario

PaaS — Platform as a Service: piattaforma gestita per build e run delle applicazioni.

Runtime gestito — Ambiente di esecuzione (es. container/app service) mantenuto dal provider.

In prova: Se chiedono «non gestisco il SO ma carico il codice» !' PaaS.

Riferimenti: Strategia Cloud PA

3. SaaS — Software as a Service

Applicativo completo erogato via rete: l'ente configura utenti, ruoli e opzioni; non patcha l'infrastruttura sottostante.

Nel SaaS il fornitore eroga l'applicazione completa (posta, collaboration, CRM, ticketing, protocollo in cloud, ecc.) accessibile tipicamente via browser o client ufficiale. L'amministrazione gestisce utenze, permessi, integrazioni (SSO/SPID), retention e dati di business inseriti nel servizio, ma non amministra server, SO o patch infrastrutturali dell'applicativo.

Per la PA sono critici: trattamento dati (ruoli titolare/responsabile ex art. 28 GDPR), residenza e classificazione dei dati, clausole contrattuali, export e exit, logging degli accessi admin, integrazione con SPID/CIE. Il modello SaaS sposta molto rischio operativo sul provider, ma non elimina accountability dell'ente sul trattamento e sulla scelta del servizio qualificato ove richiesto.

Trappola d'esame: attribuire all'ente utente la patch di hypervisor/SO in un SaaS puro. Risposta corretta: l'ente si occupa di configurazione, accessi, classificazione e uso corretto; il provider dell'infrastruttura e dell'applicazione. Ricorda la frase d'oro: in SaaS la patch infrastrutturale non è dell'amministrazione utente.

Glossario

SaaS — Software as a Service: software pronto all'uso erogato come servizio.

Responsabile del trattamento — Fornitore che tratta dati per conto del titolare PA, con contratto ex art. 28 GDPR.

In prova: Frase da ricordare: in SaaS la patch infrastrutturale non è dell'amministrazione utente.

Riferimenti: Strategia Cloud PA · GDPR art. 28

4. On-premise vs cloud

On-premise massimizza controllo fisico; il cloud offre elasticità e costi operativi diversi, con vincoli su dati e residenza.

L'infrastruttura on-premise è gestita nei locali o nel datacenter sotto controllo diretto dell'ente: pieno controllo su hardware, rete e accessi fisici, ma investimenti capitali, capacità da dimensionare «per picco», refresh tecnologico e oneri di manutenzione su personale interno o fornitori. Il cloud (pubblico, privato o hybrid) sposta verso modelli a consumo, elasticità e servizi gestiti.

La scelta non è solo economica: dipendono classificazione dei dati, requisiti di latenza e connettività, competenze interne, vincoli regolatori PA (qualificazione ACN, PSN), strategie di backup/DR e rischio di lock-in. Spesso si adottano modelli ibridi: sistemi legacy o ad altissima criticità a terra, nuovi servizi in cloud qualificato.

In sintetica: due vantaggi e due rischi per ciascun modello, poi il criterio decisivo per la PA = classificazione dati + conformità al quadro ACN/PSN + competenze. Non contrapporre «sicuro vs insicuro»: parla di controllo, responsabilità condivisa e misure adeguate al rischio.

Glossario

On-premise — Infrastruttura ospitata e gestita presso l'ente o un datacenter sotto suo controllo diretto.

Hybrid cloud — Combinazione di risorse on-premise e cloud, integrate operativamente.

In prova: Non contrapporre «sicuro vs insicuro»: parla di controllo, responsabilità condivisa e vincoli di classificazione.

Riferimenti: Strategia Cloud PA · Quadro ACN

5. Classificazione dati: ordinario, critico, strategico

La classificazione guida dove possono risiedere i dati della PA e quali servizi cloud sono ammessi.

Nel percorso di cloud enablement della PA italiana i dati e i servizi sono classificati, in sintesi didattica, in ordinari, critici e strategici in base a impatto su sicurezza nazionale, continuità dei servizi essenziali, riservatezza e sensibilità. La classificazione non è un'etichetta informatica fine a sé stessa: determina i vincoli di deployment e il livello di cloud qualificato utilizzabile.

Dati/servizi a criticità crescente richiedono ambienti più controllati (cloud qualificati di livello adeguato, PSN, misure rafforzate di cifratura, logging e accesso). L'ente deve inventariare trattamenti e servizi, classificarli con le strutture competenti e solo dopo scegliere il target infrastrutturale. Errori di classificazione espongono a non conformità e a rischi operativi gravi.

Per l'esame: spiega i tre livelli in termini di impatto e collega «più critico !» più vincoli». Evita di inventare elenchi di articoli o percentuali; resta sul ragionamento ACN/strategia cloud PA. Esempio: sito informativo istituzionale "" anagrafe critica "" asset strategici di sicurezza nazionale.

Glossario

Dato/servizio strategico — Asset a massimo impatto; tipicamente soggetto ai vincoli più stringenti di collocation/qualificazione.

Dato ordinario — Asset a impatto contenuto; con più opzioni di cloud qualificato, sempre nel rispetto della privacy.

In prova: Collega sempre classificazione !» scelta del tipo di cloud/PSN, non solo alla cifratura.

Riferimenti: Strategia Cloud PA · Quadro ACN sulla qualificazione cloud

6. PSN e cloud qualificati ACN

Il Polo Strategico Nazionale e i cloud qualificati ACN sono i riferimenti di adozione cloud per molte pubbliche amministrazioni.

L'Agenzia per la Cybersicurezza Nazionale (ACN) gestisce il percorso di qualificazione dei servizi cloud per la PA: i provider devono dimostrare requisiti di sicurezza, affidabilità, trasparenza e conformità per poter erogare servizi alle amministrazioni in funzione della classificazione dei dati/servizi. Non tutti i cloud commerciali «di mercato» sono automaticamente utilizzabili per ogni classe di dato pubblico.

Il Polo Strategico Nazionale (PSN) è l'infrastruttura di riferimento per ospitare servizi e dati a elevata criticità della PA, in un modello di consolidamento e rafforzamento della sicurezza nazionale del cloud pubblico. Le amministrazioni devono pianificare migrazioni e adoption secondo le roadmap, i cataloghi dei servizi qualificati e i vincoli vigenti, coinvolgendo RTD e strutture di sicurezza.

Risposta da concorso: ACN = qualificazione e cybersicurezza nazionale; PSN = polo infrastrutturale strategico; classificazione dati = criterio di scelta del target. Distingui da AgID (agenda digitale, linee guida su riuso/documento/interoperabilità) senza contrapposizioni inutili: operano su piani diversi e complementari.

Glossario

ACN — Agenzia per la Cybersicurezza Nazionale: tra i compiti, qualificazione dei servizi cloud per la PA.

PSN — Polo Strategico Nazionale: infrastruttura cloud di riferimento per servizi/dati ad alta criticità.

In prova: Non confondere AgID e ACN. Per cloud PA cita qualificazione ACN + PSN + classificazione.

Riferimenti: ACN — qualificazione cloud · Polo Strategico Nazionale

Interoperabilità applicativa

Far dialogare sistemi diversi: tecnica, semantica e organizzativa; API REST, PDND e once-only.

Da ricordare

Non confondere PDND (condivisione dati via API) con backup o autenticazione. Once-only = conseguenza pratica dell'interoperabilità.

1. Interoperabilità tecnica

Protocolli, formati e API (spesso REST + HTTP + JSON) consentono a sistemi eterogenei di scambiarsi messaggi.

L'interoperabilità tecnica riguarda la capacità di due sistemi di connettersi e scambiare dati usando protocolli e formati condivisi. In ambito moderno prevalgono API HTTP, spesso in stile REST, con payload JSON o XML, autenticazione tramite token (OAuth2/JWT) o mTLS, e API gateway di sicurezza con rate limiting e logging.

Senza accordo tecnico (endpoint, versionamento, timeout, codici errore, TLS obbligatorio) l'integrazione fallisce anche se i dati «sembrano» gli stessi a livello umano. Per la PA, le Linee guida AgID sull'interoperabilità e i pattern di API design nazionali orientano verso soluzioni coerenti, documentate (OpenAPI) e pubblicabili nei cataloghi (anche verso PDND).

In prova: definisci l'interoperabilità tecnica, fai un esempio REST su HTTPS, cita versionamento (/v1/) e distinzione dal piano semantico. Tecnica = «come si parla» (protocollo/formato); semantica = «cosa significa». Per l'assistente IT: leggere una specifica OpenAPI e provare un GET autenticato è il minimo operativo.

Glossario

API — Application Programming Interface: interfaccia che consente a sistemi diversi di scambiare dati/funzioni.

OpenAPI — Formato standard per documentare API HTTP (endpoint, schemi, autenticazione).

In prova: Tecnica = «come si parla» (protocollo/formato). Semantica = «cosa significa».

Riferimenti: CAD · Linee guida AgID interoperabilità

2. Interoperabilità semantica

Stesso significato dei dati tra sistemi: vocabolari controllati, ontologie e modelli condivisi.

Due enti possono scambiare un campo «stato» in JSON e intendere cose diverse (stato civile vs stato della pratica vs stato della macchina). L'interoperabilità semantica assicura che i concetti siano allineati tramite vocabolari controllati, ontologie, codifiche nazionali (elenchi territoriali, classificazioni) e data model condivisi pubblicati e versionati.

È un lavoro organizzativo e di governance dei dati tanto quanto tecnico: servono glossari, responsabilità sul significato dei campi (data owner), qualità anagrafiche, regole di mapping e test di riconciliazione. La PDND e i cataloghi di e-service aiutano a pubblicare descrizioni chiare delle risorse esposte e degli attributi richiesti.

Esempio d'esame: codice fiscale vs partita IVA; indirizzo strutturato (via, CAP, comune) vs stringa libera; date in ISO 8601 vs formati locali ambigui. Senza semantica, l'API tecnica propaga errori di senso a velocità industriale. Chiudi collegando semantica !' once-only: riusare dati ha senso solo se significano la stessa cosa.

Glossario

Vocabolario controllato — Insieme definito di termini/codici con significato condiviso tra sistemi.

Data model — Modello che definisce entità, attributi e relazioni con semantica esplicita.

In prova: Se chiedono un esempio di fallimento semantico, usa «stesso nome campo, significato diverso».

Riferimenti: Linee guida AgID interoperabilità

3. CRUD e REST

CRUD (Create, Read, Update, Delete) si mappa tipicamente su metodi HTTP in API REST orientate alle risorse.

CRUD indica le quattro operazioni base sulle risorse informative: creazione, lettura, aggiornamento ed eliminazione. Nello stile REST le risorse sono individuate da URI e le operazioni si esprimono con metodi HTTP: tipicamente POST (create), GET (read), PUT/PATCH (update), DELETE (delete), con attenzione a idempotenza (GET, PUT, DELETE tipicamente idempotenti; POST no).

REST non è un protocollo ma uno stile architetturale: stateless lato server tra le richieste, risorse indirizzabili, uso corretto di status code HTTP, rappresentazione JSON/XML. Per i quiz PAT basta padronanza di risorse, metodi, JSON, autenticazione e differenza tra collezione (`/pratiche`) e risorsa (`/pratiche/42`).

Esempio: GET `/rest/pratiche/v1/pratiche/42` legge la pratica 42; POST sulla collezione ne crea una nuova. Ricorda che non ogni API HTTP è «RESTful» in senso stretto, ma il linguaggio d'esame usa REST in senso ampio. Possibile domanda: associa metodo !" operazione CRUD senza esitazioni.

Glossario

REST — Stile architetturale per API basato su risorse, URI e metodi HTTP.

CRUD — Create, Read, Update, Delete: operazioni elementari sui dati.

In prova: Associa mentalmente GET!'Read, POST!'Create, PUT/PATCH!'Update, DELETE!'Delete.

Riferimenti: Linee guida AgID interoperabilità / API

4. PDND — Piattaforma Digitale Nazionale Dati

La PDND è l'hub nazionale per lo scambio dati tra soggetti abilitati tramite API interoperabili.

La Piattaforma Digitale Nazionale Dati (PDND) abilita l'interoperabilità tra pubbliche amministrazioni (e soggetti aderenti) esponendo e consumando API in un ambiente governato: catalogo degli e-service, accordi di interoperabilità, autenticazione dei soggetti (spesso mTLS/certificati), policy di accesso ai dataset e tracciatura degli scambi.

Non è un database unico nazionale né un sistema di backup o di conservazione. È un'infrastruttura di scambio: ogni ente resta responsabile dei propri dati e delle API che espone o invoca. Serve a realizzare casi d'uso once-only e a ridurre integrazioni punto-punto non governate, fragili e opache.

In risposta: definizione !' API/e-service !' soggetti abilitati !' differenza da «unico data lake centrale». Collega a CAD/interoperabilità e al diritto del cittadino di non ridare dati già noti alla PA. Trappola tipica: PDND "" SPID e "" conservazione a norma.

Glossario

PDND — Piattaforma Digitale Nazionale Dati: hub per interoperabilità API tra PA.

E-service — Servizio digitale esposto via API e descritto nel catalogo di interoperabilità.

In prova: Trappola: PDND "" SPID e "" conservazione. PDND = scambio dati via API governate.

Riferimenti: CAD / interoperabilità · Documentazione PDND

5. Principio once-only

Il cittadino non deve ridare dati già in possesso della PA: richiede interoperabilità e basi dati di qualità.

Once-only è un principio europeo e nazionale di semplificazione amministrativa: le amministrazioni riusano informazioni già raccolte, chiedendo all'utente solo ciò che non possono acquisire altrimenti dalle fonti autoritative. Non si realizza con un modulo PDF più corto, ma con integrazioni affidabili tra sistemi, basi giuridiche del trattamento e responsabilità chiare sul dato.

Prerequisiti: anagrafiche di qualità, API disponibili (anche via PDND), finalità e basi legali corrette, gestione degli errori di matching (omonimie, dati non aggiornati). Un dato errato propagato automaticamente può peggiorare il servizio e generare atti viziati: qualità e governance sono parte integrante del principio, non un optional.

Esempio: presentare un'istanza senza ricaricare ISEE, residenza o stato di famiglia se l'ente può interrogarli dalle fonti competenti. In prova collega once-only !" interoperabilità tecnica/semantica !" diritti di cittadinanza digitale del CAD. Chiudi con: «once-only non è magia: è API + qualità dati + privacy».

Glossario

Once-only — Principio per cui il cittadino non ridà dati già detenuti dalla PA.

Fonte autoritativa — Banca dati ufficiale da cui attingere un attributo con valore di riferimento.

In prova: Definisci + prerequisito tecnico (API/PDND) + attenzione a qualità dei dati e privacy.

Riferimenti: CAD · Quadro europeo once-only

6. Esempio di endpoint REST

Un URI REST individua una risorsa: metodo HTTP + percorso versionato + identificativo.

Esempio didattico: `https://api.ente.example/rest/nome-api/v1/resources/1234`. Si legge come: schema HTTPS (obbligo di canale cifrato), host dell'API gateway dell'ente, prefisso rest, nome dell'API, versione v1, collezione `resources`, risorsa con id `1234`. Un GET su quell'URL recupera la rappresentazione JSON della risorsa, se l'caller è autenticato e autorizzato.

Buone pratiche da citare in prova: versionamento esplicito; nomi di risorse al plurale; autenticazione (token Bearer, mTLS verso PDND ove previsto); status code corretti (200, 201, 400, 401, 403, 404, 429, 500); documentazione OpenAPI aggiornata; correlazione request-id nei log. L'host «example» è fittizio ma lo schema è quello atteso.

Possibile domanda: «Cosa restituisce GET su .../resources/1234?» !' la sola risorsa 1234 (se autorizzati), non l'intera collezione. POST sulla collezione crea; PUT/PATCH sull'id aggiorna; DELETE sull'id elimina (secondo le policy e i soft-delete). Scomporre l'URL pezzo per pezzo in orale dimostra competenza concreta.

Glossario

URI — Identificativo uniforme della risorsa (path + eventuale query) su cui agisce il metodo HTTP.

Status code — Codice numerico HTTP che comunica l'esito della richiesta (2xx ok, 4xx client, 5xx server).

In prova: Scomponi l'URL pezzo per pezzo in sede orale/sintetica: mostra che sai leggere un endpoint.

Riferimenti: Linee guida AgID API / interoperabilità

Database relazionali e SQL

Modello relazionale, chiavi, normalizzazione, SQL di base e ACID — livello operativo da assistente.

Da ricordare

Per una sintetica: modello relazionale !' chiave/integrità !' esempio SQL !' ACID o sicurezza (injection) se chiesto.

1. Modello relazionale e chiave primaria

Tabella = relazione, riga = tupla, colonna = attributo; la chiave primaria identifica univocamente ogni riga.

Nel modello relazionale i dati sono organizzati in relazioni (tabelle) composte da tuple (righe) e attributi (colonne) con domini definiti (tipi: intero, testo, data, booleano...). L'ordine delle righe non ha significato logico; l'identità della riga è data dalla chiave. Questo modello è alla base dei DBMS più usati nella PA (PostgreSQL, MySQL/MariaDB, Oracle, SQL Server, ecc.).

La chiave primaria (PRIMARY KEY) è un attributo o un insieme minimo di attributi che identifica univocamente ciascuna tupla e non ammette NULL. Può essere naturale (codice fiscale, se ammissibile e stabile) o surrogata (id numerico/UUID). Scelte di chiave influenzano join, indici, qualità dei dati e facilità di integrazione con altri sistemi.

In prova: definisci tabella/riga/colonna, spiega PK con un esempio (tabella Dipendenti con id_dipendente) e cita vincolo di univocità. Non confondere chiave primaria con indice: la PK implica un vincolo logico di unicità; l'indice è la struttura fisica che spesso la supporta.

Glossario

Chiave primaria — Attributo (o insieme) che identifica univocamente una riga e non è nullo.

DBMS — Database Management System: software che gestisce database (es. PostgreSQL).

In prova: Non confondere chiave primaria con indice: la PK implica un vincolo di unicità; l'indice è struttura fisica di accesso.

Riferimenti: Manuali SQL / programma tecnico Assistente informatico

2. Chiave esterna e integrità referenziale

La foreign key collega tabelle e impedisce riferimenti a righe inesistenti, preservando l'integrità referenziale.

Una chiave esterna (FOREIGN KEY) in una tabella referencia la chiave primaria (o unica) di un'altra tabella. Esempio: Prenotazioni.id_sala !' Sale.id. L'integrità referenziale impedisce di inserire una prenotazione per una sala inesistente o, secondo le regole ON DELETE/UPDATE (RESTRICT, CASCADE, SET NULL), gestisce cascate o restrizioni in modo consapevole.

Senza FK (o senza controlli applicativi equivalenti e testati) il database può accumulare orfani e inconsistenze difficili da sanare. Nella PA, anagrafiche, fascicoli, utenze e profili collegati traggono grande beneficio da vincoli dichiarati nel DBMS, non solo nel codice applicativo che può essere aggirato da script o accessi diretti.

Risposta tipica: definizione FK + esempio a due tabelle disegnato mentalmente + menzione di ON DELETE RESTRICT/CASCADE come comportamento da progettare (cascata pericolosa se non voluta). Chiudi: integrità referenziale = i riferimenti puntano sempre a righe esistenti.

Glossario

Integrità referenziale — Garanzia che i riferimenti tra tabelle puntino a righe esistenti, secondo le regole definite.

Foreign key — Colonna (o insieme) che referencia la chiave di un'altra tabella.

In prova: Disegna mentalmente due tabelle collegate: è la risposta più chiara in orale.

3. SQL di base e JOIN

SELECT/FROM/WHERE, DML (INSERT/UPDATE/DELETE), aggregazioni e JOIN per combinare tabelle.

SQL distingue tipicamente DDL (definizione schemi: CREATE/ALTER/DROP), DML (manipolazione dati: INSERT/UPDATE/DELETE) e interrogazioni. Le basi d'esame: `SELECT colonne FROM tabella WHERE condizione`; funzioni di aggregazione `COUNT`, `SUM`, `AVG` con `GROUP BY` e `HAVING`; ordinamento con `ORDER BY`.

Il JOIN combina righe di più tabelle sulla base di predicati (di solito uguaglianza tra PK e FK). INNER JOIN restituisce solo le corrispondenze; LEFT JOIN conserva le righe della tabella di sinistra anche senza match (utile per trovare «senza utenza» o «senza pratica collegata»). Capire la differenza evita errori tipici nei report e nelle estrazioni per trasparenza.

Esempio: ``SELECT d.nome, u.login FROM dipendenti d JOIN utenze u ON d.id = u.id_dipendente WHERE d.attivo = true``. In sintetica scrivi una query corta e corretta piuttosto che prosa vaga: la commissione valuta subito se sai il JOIN.

Glossario

INNER JOIN — Join che restituisce solo le righe con corrispondenza in entrambe le tabelle.

LEFT JOIN — Join che conserva tutte le righe della tabella di sinistra, con NULL dove manca il match.

In prova: Porta a memoria un esempio di INNER JOIN a due tabelle e la differenza con LEFT JOIN.

4. Normalizzazione

La normalizzazione riduce ridondanze e anomalie di aggiornamento; conoscere 1NF, 2NF e 3NF in sintesi.

La normalizzazione organizza gli attributi in relazioni per limitare ridondanza e anomalie di inserimento/aggiornamento/cancellazione. 1NF: valori atomici, niente gruppi ripetitivi in una cella. 2NF: ogni attributo non chiave dipende dall'intera chiave (rilevante con chiavi composite). 3NF: niente dipendenze transitive di non-chiavi da altre non-chiavi (es. città che dipende dal CAP già presente).

Nella pratica si bilancia normalizzazione e prestazioni (a volte denormalizzando in modo controllato per report o data warehouse). Per un assistente informatico basta saper spiegare il «perché» (un solo punto di verità per ciascun fatto) con un esempio (indirizzo ripetuto in mille fatture vs tabella Anagrafiche collegata da FK).

In prova: definisci l'obiettivo, elenca 1-2-3 NF in una frase ciascuna, fai un esempio di ridondanza evitata. Non serve dimostrazione formale con dipendenze funzionali complete: conta chiarezza e senso pratico.

Glossario

Ridondanza — Ripetizione dello stesso fatto in più punti, fonte di inconsistenze.

Denormalizzazione — Scelta consapevole di ridondanza controllata per migliorare letture/report.

In prova: Non serve dimostrazione formale: obiettivo + 1NF/2NF/3NF in sintesi + esempio.

5. Proprietà ACID

Atomicità, Consistenza, Isolamento, Durabilità: garanzie delle transazioni nei DBMS affidabili.

Una transazione è una unità di lavoro che porta il database da uno stato consistente a un altro. ACID: Atomicità (tutto o niente: commit o rollback); Consistenza (rispetto dei vincoli di schema e regole); Isolamento (transazioni concorrenti non si «calpestano» in modo anomalo); Durabilità (dopo il commit i dati restano anche in caso di crash, entro i limiti di logging e storage del sistema).

Esempio classico: trasferimento tra due conti — se fallisce il secondo UPDATE, si annulla anche il primo (atomicità). I livelli di isolamento (read committed, repeatable read, serializable) regolano il trade-off tra correttezza e throughput: più isolamento, meno anomalie, spesso meno concorrenza.

Per il quiz: espandi correttamente l'acronimo in italiano e fai un esempio di atomicità. Non confondere ACID con CAP theorem (contesto sistemi distribuiti NoSQL/distribuiti, piano diverso). Nei sistemi PA critici (protocollo, pagamenti, prenotazioni) ACID è un argomento di affidabilità da citare.

Glossario

Transazione — Sequenza di operazioni trattata come unità atomica dal DBMS.

Commit / Rollback — Conferma definitiva oppure annullamento completo della transazione.

In prova: ACID = Atomicità, Consistenza, Isolamento, Durabilità — ordine e significato esatti.

6. Indici

Gli indici accelerano le letture al costo di spazio e di scritture più lente da mantenere aggiornate.

Un indice è una struttura ausiliaria (spesso B-tree, a volte hash o full-text) che permette di trovare le righe senza scandire l'intera tabella (full table scan). È utile su colonne usate frequentemente in WHERE, JOIN e ORDER BY; la PRIMARY KEY ha di regola un indice univoco sottostante.

Il costo: ogni INSERT/UPDATE/DELETE deve aggiornare gli indici coinvolti; troppi indici inutili peggiorano le scritture, occupano spazio e complicano la manutenzione. La scelta corretta si basa sul workload reale e sull'analisi dei piani di esecuzione (EXPLAIN), non su intuizioni isolate.

In risposta: beneficio (lookup e join più veloci) + costo (scritture/spazio) + esempio (indice su codice_fiscale per ricerche frequenti in help desk). Frase pronta: «più veloci le SELECT, più costose le scritture». Distingui indice univoco da vincolo UNIQUE/PK.

Glossario

Indice — Struttura fisica ausiliaria che accelera l'accesso alle righe su certe colonne.

Full table scan — Lettura sequenziale di tutta la tabella, tipica senza indici adeguati.

In prova: Frase pronta: «più veloci le SELECT, più costose le scritture».

7. SQL injection

Rischio grave se l'input utente è concatenato nella query; mitigazione principale: prepared statement / query parametrizzate.

La SQL injection avviene quando un input malevolo altera la struttura della query SQL (es. concatenando `OR 1=1`, chiudendo stringhe o aggiungendo `UNION SELECT`). Può portare a lettura di dati non autorizzati, bypass del login, modifica o cancellazione di dati, fino a comandi amministrativi se i privilegi DB sono eccessivi. È tra le vulnerabilità web più note e ancora frequenti.

Mitigazioni: statement preparati e bind dei parametri (prepared statement); validazione e encoding dell'input; minimo privilegio dell'account DB dell'applicazione (niente DDL se non serve); ORM usati correttamente (non con SQL grezzo concatenato); WAF come difesa aggiuntiva non sostitutiva. Mai costruire SQL con concatenazione di stringhe provenienti dall'utente.

Esempio didattico: login con `username` interpolato nella WHERE. In prova PAT collega injection a sicurezza applicativa, CIA (soprattutto C e I) e least privilege sul DB. Schema risposta: definizione !' esempio concettuale !' prepared statement come rimedio principale.

Glossario

Prepared statement — Query con parametri separati dal codice SQL, che impedisce l'alterazione della struttura.

Least privilege — Principio per cui l'account applicativo ha solo i permessi DB strettamente necessari.

In prova: Definizione !' esempio concettuale !' prepared statement come rimedio principale.

Riferimenti: OWASP Top 10 (SQL Injection) · Buone pratiche sicurezza applicativa

Reti e modello OSI

Stack a 7 livelli, TCP/IP, indirizzamento e servizi di rete essenziali in ambito PA.

Da ricordare

Firewall " " antivirus. Firewall filtra rete; antivirus analizza malware su endpoint. CIA: Confidenzialità, Integrità, Disponibilità.

1. I 7 livelli OSI

Fisico, Data Link, Rete, Trasporto, Sessione, Presentazione, Applicazione: modello di riferimento per ragionare sulle reti.

Il modello OSI (Open Systems Interconnection) suddivide la comunicazione in sette livelli: 1 Fisico (bit su mezzo trasmissivo), 2 Data Link (frame, indirizzi MAC, switch/VLAN), 3 Rete (pacchetti, IP, routing), 4 Trasporto (segmenti/datagrammi, TCP/UDP, porte), 5 Sessione (gestione dialogo), 6 Presentazione (sintassi, eventuale cifratura in chiave didattica), 7 Applicazione (HTTP, SMTP, DNS lato utente dei servizi).

È un modello pedagogico e di troubleshooting: «a che livello è il problema?» (cavo/ottica vs VLAN vs routing vs porta TCP chiusa vs bug applicativo). Nella realtà i protocolli non mappano sempre in modo netto sui sette strati, ma la scala a 7 resta richiesta d'esame e utile per comunicare con colleghi di rete.

Memorizza i nomi in ordine (dal basso all'alto o viceversa) e un esempio di dispositivo/PDU/funzione per i livelli 1–4 e 7, i più interrogati: switch"HL2, router"HL3, TCP"HL4, HTTP"HL7. Una mnemonica personale aiuta in orale sotto stress.

Glossario

OSI — Open Systems Interconnection: modello di riferimento a 7 livelli per le reti.

PDU — Protocol Data Unit: unità dati tipica di un livello (frame, pacchetto, segmento...).

In prova: Elenca i 7 livelli senza esitazioni; aggiungi un esempio (switch"HL2, router"HL3, TCP"HL4, HTTP"HL7).

Riferimenti: Programma tecnico reti / modello OSI

2. Modello TCP/IP

Nella pratica si usa TCP/IP: livelli Network (IP), Transport (TCP/UDP) e Application (HTTP, DNS, SMTP...).

Lo stack TCP/IP, usato su Internet e nelle reti aziendali, è più compatto dell'OSI: tipicamente Link, Internet (IP), Transport (TCP/UDP), Application. IP indirizza e instrada i pacchetti; TCP fornisce trasporto affidabile e orientato alla connessione (handshake, ritrasmissione, controllo di flusso); UDP è datagramma senza garanzia di consegna, utile per DNS, VoIP o real-time dove la latenza conta più della ritrasmissione.

Confrontare OSI e TCP/IP è domanda classica: OSI è modello teorico a 7 livelli; TCP/IP è l'architettura implementata nella pratica. HTTP, DNS, SMTP, SSH, HTTPS vivono nello strato applicativo TCP/IP (che «assorbe» in parte sessione/presentazione OSI).

In sintetica: disegna i due stack affiancati e indica dove cadono IP, TCP e HTTPS. Frasi da ricordare: TCP = affidabile; UDP = veloce/senza garanzie; IP = indirizzamento/routing. Per troubleshooting: ping/traceroute (IP), test porta (TCP), dig/nslookup (DNS).

Glossario

TCP — Transport Control Protocol: trasporto affidabile, connesso, con controllo di flusso/congestione.

UDP — User Datagram Protocol: trasporto non connesso, a basso overhead, senza garanzia di consegna.

IP — Internet Protocol: indirizzamento e instradamento dei pacchetti tra reti.

In prova: TCP = affidabile; UDP = veloce/senza garanzie. IP = indirizzamento/routing.

3. LAN/WAN, switch, router, firewall

LAN locale vs WAN geografica; switch L2, router L3, firewall filtra connessioni secondo policy.

Una LAN (Local Area Network) collega dispositivi in un'area limitata (sede, piano, campus); una WAN collega siti distanti (sedi provinciali, collegamenti geografici, Internet). Lo switch opera tipicamente a livello 2 (inoltre su indirizzi MAC, VLAN per segmentare broadcast domain); il router a livello 3 (inoltre tra reti IP diverse, spesso con ACL di base).

Il firewall applica regole di sicurezza sul traffico (spesso stateful: tiene traccia delle connessioni consentite e blocca ciò che non è autorizzato, in ingresso e/o uscita). Non sostituisce antivirus, EDR o patching degli endpoint: è un controllo di rete. In PA si combinano firewall perimetrali, segmentazione (VLAN/zone), reverse proxy e, ove adottato, approcci Zero Trust.

Schema d'esame: LAN/WAN !' dispositivo !' livello OSI !' funzione. Evita errori tipici: «lo switch assegna gli IP» (quello è DHCP); «il firewall è un antivirus». Firewall " antivirus. Switch "H L2, router "H L3.

Glossario

Firewall stateful — Filtro che consente risposte a sessioni legittime già aperte e blocca traffico non autorizzato.

VLAN — Rete locale virtuale: segmentazione logica a livello 2 su uno o più switch.

In prova: Firewall " antivirus. Switch "H L2, router "H L3.

4. DNS, DHCP e NAT

DNS risolve nomi in IP; DHCP configura automaticamente i client; NAT traduce indirizzi privati/pubblici.

Il DNS (Domain Name System) traduce nomi logici (www.provincia.tn.it) in indirizzi IP e viceversa (PTR). È critico per la disponibilità dei servizi: un DNS errato o irraggiungibile «rompe» applicazioni anche se i server sono attivi. Supporta record A/AAAA, MX per la posta, CNAME, TXT (SPF/DKIM) e altri servizi.

Il DHCP assegna dinamicamente IP, maschera, gateway predefinito e server DNS ai client, riducendo errori di configurazione manuale e facilitando la gestione di flotte di PC. Il NAT (Network Address Translation) permette a molti host con indirizzi privati di uscire verso Internet con pochi IP pubblici, traducendo gli indirizzi; il port forwarding/DNAT espone selettivamente servizi interni — da usare con cautela.

In prova: una frase di funzione per ciascuno. Domanda tipica: «Chi assegna l'IP al PC in ufficio?» !' DHCP (di solito). «Perché non apro il sito ma il ping all'IP funziona?» !' spesso DNS. Schema: DNS = nome!IP; DHCP = autoconfigurazione; NAT = traduzione indirizzi.

Glossario

DNS — Domain Name System: risoluzione di nomi in indirizzi IP.

DHCP — Dynamic Host Configuration Protocol: assegnazione automatica dei parametri di rete.

NAT — Network Address Translation: traduzione di indirizzi IP (tipicamente privato!pubblico).

In prova: DNS = nome!IP; DHCP = autoconfigurazione; NAT = traduzione indirizzi.

5. HTTPS e TLS

HTTPS è HTTP trasportato su TLS: confidenzialità e integrità del canale tra client e server.

TLS (Transport Layer Security) negozia cifratura e autenticazione del canale, tipicamente con certificati X.509 del server verificati rispetto a una certification authority. HTTPS è semplicemente HTTP over TLS sulla porta 443. Protegge da intercettazione e manipolazione del traffico sul percorso, ma non sostituisce controlli applicativi (XSS, SQL injection) né l'autorizzazione lato server dopo il login.

Nella PA l'uso di HTTPS su portali, intranet esposte e API è standard di sicurezza minimo. Vanno gestiti rinnovo certificati (scadenze!), versioni TLS aggiornate (disabilitare protocolli obsoleti), cipher suite adeguate e HSTS ove appropriato. Certificati validi e catene di trust corrette evitano warning che abitano gli utenti a cliccare «continua» in modo rischioso.

Collega a CIA: TLS protegge soprattutto confidenzialità e integrità del canale; la disponibilità resta tema separato (DDoS, redundancy, certificati scaduti che bloccano il servizio). Non dire che HTTPS «cifra il database»: cifra il trasporto tra client e server.

Glossario

TLS — Protocollo di sicurezza del canale su cui viaggia HTTPS.

Certificato X.509 — Documento digitale che lega una chiave pubblica a un'identità (es. nome host), firmato da una CA.

In prova: HTTPS = HTTP + TLS. Non dire che «cifra il database»: cifra il trasporto.

Riferimenti: Buone pratiche sicurezza web PA

6. Porte note

Porte TCP/UDP tipiche: 80/443 web, 22 SSH, 25/587 mail, 53 DNS — utili per firewall e troubleshooting.

Le porte identificano i servizi di trasporto su un host (coppia IP:porta). Conoscere le porte «note» aiuta a leggere regole firewall, log di IDS e ticket di rete. Esempi richiesti d'esame: 80 HTTP, 443 HTTPS, 22 SSH, 53 DNS (UDP/TCP), 25 SMTP, 587 submission posta; spesso si cita anche 3389 RDP (da ricordare con i rischi di esposizione).

Aprire porte senza necessità aumenta la superficie d'attacco: principio di minimo servizio esposto. In reti PA si pubblicano solo i servizi necessari, preferibilmente dietro reverse proxy/WAF, con autenticazione forte e segmentazione; l'accesso admin (SSH/RDP) va limitato a bastion/VPN, non aperto a Internet.

Quiz: «Su quale porta gira HTTPS?» !' 443. «SSH?» !' 22. «DNS?» !' 53. Abbina sempre porta !' protocollo !' rischio se esposta indiscriminatamente. In troubleshooting: «connection refused» vs «timeout» raccontano storie diverse (servizio spento vs filtro/firewall).

Glossario

Porta — Numero a 16 bit che identifica un endpoint di trasporto su un host (0–65535).

Superficie d'attacco — Insieme dei punti esposti attraverso cui un attaccante può tentare di compromettere il sistema.

In prova: Memorizza almeno 80, 443, 22, 53, 25/587.

Virtualizzazione: VM e container

Isolamento delle risorse, densità, orchestrazione — linguaggio tipico delle prove PAT recenti.

Da ricordare

Container " " hypervisor multi-OS: il container non gestisce direttamente l'hardware e tipicamente non ospita SO guest diversi come una VM.

1. VM e hypervisor

L'hypervisor virtualizza l'hardware; ogni macchina virtuale esegue un sistema operativo guest completo.

La virtualizzazione server consente di eseguire più macchine virtuali (VM) su un unico host fisico. L'hypervisor (tipo 1 bare metal, direttamente sull'hardware, o tipo 2 hosted su un SO) astrae CPU, memoria, storage e rete, allocando risorse alle VM. Ogni VM ha un proprio SO guest, driver e applicazioni, con isolamento forte rispetto alle altre VM sullo stesso host.

Vantaggi: consolidamento hardware (meno server fisici), snapshot e backup a livello VM, clonazione rapida, live migration, laboratori e test isolati senza hardware dedicato. Costi: overhead di memoria e CPU rispetto al bare metal, licenze di hypervisor/guest, complessità di gestione e necessità di skill specifiche. È il fondamento di molti cloud IaaS.

In prova: definisci hypervisor e VM, cita isolamento e SO guest completo, confronta subito dopo con i container. Frase d'oro: VM = hardware virtuale + SO guest completo. Esempio PA: server di protocollo e di test sullo stesso blade, isolati come VM distinte.

Glossario

Hypervisor — Software che astrae l'hardware e ospita macchine virtuali.

SO guest — Sistema operativo eseguito all'interno di una macchina virtuale.

In prova: VM = hardware virtuale + SO guest completo.

Riferimenti: Programma tecnico virtualizzazione PAT

2. Container

Il container condivide il kernel dell'host e incapsula runtime e dipendenze dell'applicazione sopra il sistema operativo.

I container (ecosistema Docker e analoghi) isolano processi con namespace e cgroup del kernel Linux, impacchettando codice e dipendenze in immagini riproducibili. Non includono un kernel proprio: condividono quello dell'host. Partono in secondi, consumano meno risorse delle VM e favoriscono il principio «build once, run anywhere» (con le dovute configurazioni di ambiente).

Sono ideali per microservizi e pipeline CI/CD: lo stesso artefatto gira in test e produzione. Restano legati al kernel host: non si esegue tipicamente un Windows guest dentro un container Linux come si farebbe con una VM completa. L'isolamento è forte a livello processo, ma meno «assoluto» di una VM rispetto al kernel.

Frase d'esame: «container = isolamento applicativo su kernel condiviso; VM = SO guest completo su hypervisor». Insisti sul kernel condiviso: è il discriminante che la commissione cerca. Per l'assistente IT: saper leggere un Dockerfile e un docker-compose è valore operativo.

Glossario

Immagine container — Pacchetto immutabile con applicazione e dipendenze da cui si avviano i container.

Namespace / cgroup — Meccanismi del kernel Linux per isolamento di vista risorse e limiti di CPU/RAM/IO.

In prova: Insisti sul kernel condiviso: è il discriminante rispetto alle VM.

3. Vantaggi e rischi dei container

Leggerezza, portabilità e deploy rapido; attenzione alla sicurezza dell'host condiviso e della supply chain delle immagini.

Vantaggi: densità elevata (più servizi per host), avvio rapido, portabilità tra ambienti, scaling granulare dei servizi, allineamento DevOps e rollback veloci tramite versionamento delle immagini. Consentono di standardizzare il runtime e ridurre il «funziona solo sulla mia macchina».

Rischi: fuga dal container verso l'host se il kernel o il runtime sono vulnerabili; immagini non aggiornate o provenienti da registry non fidati; segreti (password, token) cablati nelle immagini; lateral movement tra container mal segmentati sulla stessa rete. Mitigazioni: scanning delle immagini (CVE), least privilege (non root), network policy, aggiornamento runtime, registry interni firmati, secret manager.

In sintetica bilancia 2 vantaggi e 2 rischi con una mitigazione ciascuno: dimostra consapevolezza operativa da PA, non entusiasmo tecnologico acritico. Non dire solo «i container sono meglio»: mostra rischi di kernel condiviso e supply chain.

Glossario

Supply chain — Catena di fornitura del software: base image, dipendenze, registry, build pipeline.

Image scanning — Analisi automatica delle immagini alla ricerca di vulnerabilità note.

In prova: Non solo «i container sono meglio»: mostra rischi di kernel condiviso e supply chain.

4. Orchestrazione

Kubernetes e analoghi schedulano, scalano e ripristinano container su un cluster.

Quando i container crescono di numero serve un orchestratore: schedula i workload sui nodi del cluster, gestisce service discovery, bilanciamento, rolling update, autoscale e self-healing (riavvio dei pod falliti secondo lo stato desiderato). Kubernetes è lo standard de facto; esistono anche orchestratori gestiti in cloud (servizi PaaS/CaaS) che riducono l'onere del control plane.

Per la PA l'orchestrazione porta vincoli di competenza, osservabilità (metriche, log, tracing) e sicurezza (RBAC, network policy, secret management, admission control). Non è obbligatoria per ogni applicativo: un piccolo servizio può vivere su VM o su PaaS senza cluster dedicato; forzare Kubernetes ovunque aumenta costi senza benefici.

Risposta d'esame: orchestrazione = scheduling + scaling + self-healing; esempio Kubernetes; citare che aumenta complessità gestionale. Tre parole bastano se spiegate bene. Collega a scale-out: l'orchestratore è lo strumento naturale per aggiungere/rimuovere repliche.

Glossario

Self-healing — Capacità del cluster di ripristinare workload non sani secondo lo stato desiderato.

Kubernetes — Orchestratore open source de facto per container su cluster di nodi.

In prova: Associa Kubernetes a scheduling, scaling e self-healing — tre parole bastano.

5. Scale-out e scale-up

Scalabilità verticale = più risorse a un nodo; orizzontale = più nodi/istanze.

Scale-up (verticale): si aumentano CPU/RAM/disco del server o della VM. È concettualmente semplice ma ha un tetto hardware, può richiedere downtime per il resize e concentra il rischio su un unico nodo. Scale-out (orizzontale): si aggiungono istanze dietro un load balancer; tipico dei servizi stateless e dei container orchestrati, consente di crescere in modo più elastico.

Le applicazioni stateful (database monolitici tradizionali) scalano orizzontalmente con più difficoltà e richiedono sharding, replica o cluster specifici. In cloud il scale-out si combina con autoscaling basato su metriche (CPU, code, latenza). Per la PA: progettare servizi stateless dove possibile facilita continuità e migrazione cloud.

Quiz: «Aggiungo un altro server web dietro al bilanciatore» !' scale-out. «Passo da 8 a 32 GB di RAM sulla stessa VM» !' scale-up. Schema: verticale = più grosso; orizzontale = più numerosi. Collega a BC/DR: più nodi possono aumentare resilienza se distribuiti correttamente.

Glossario

Scale-up — Scalabilità verticale: più risorse sullo stesso nodo.

Scale-out — Scalabilità orizzontale: più nodi/istanze dietro bilanciatore.

In prova: Verticale = più grosso; orizzontale = più numerosi.

6. Business continuity, DR, RPO e RTO

BC = continuità operativa; DR = ripristino dopo disastro; RPO e RTO quantificano perdita dati accettabile e tempo di ripristino.

Business continuity (BC) comprende processi organizzativi e tecnologie per mantenere i servizi essenziali anche in caso di incidenti (piano, ruoli, comunicazioni, modalità degradate). Disaster recovery (DR) è il sottoinsieme orientato al ripristino dopo eventi gravi (sito down, ransomware esteso, disastro fisico), spesso su sito secondario, cloud o backup immutabili.

RPO (Recovery Point Objective): massima perdita di dati tollerabile in termini di tempo (es. «al più gli ultimi 15 minuti» !' backup/replica almeno ogni 15 minuti). RTO (Recovery Time Objective): tempo massimo accettabile per ripristinare il servizio dopo l'evento. Backup, replica sincrona/asincrona e esercitazioni di restore devono essere allineati a RPO/RTO definiti dall'ente, non scelti «a sentimento».

In prova PAT: definisci BC vs DR, poi RPO vs RTO con un esempio numerico semplice. Evita di usarli come sinonimi. Schema mnemonico: RPO = «punto nel passato» (quanto perdo); RTO = «quanto ci metto a ripartire». Un backup non testato non garantisce nessun RTO reale.

Glossario

RPO — Recovery Point Objective: quanti dati (in tempo) posso perdere al massimo.

RTO — Recovery Time Objective: quanto tempo posso impiegare per tornare operativi.

In prova: RPO = «punto nel passato»; RTO = «quanto ci metto a ripartire».

Riferimenti: Piani BC/DR ente · Buone pratiche backup

Sicurezza di base (utile a quiz e orale)

Anche se non è elenco separato nel bando Assistente, compare nelle prove affini PAT e rafforza cloud/reti/CAD.

Da ricordare

Password: mai in chiaro; hash iterativo con salt. Per autenticità del messaggio si firma con chiave privata.

1. Triade CIA

Confidenzialità, Integrità, Disponibilità: obiettivi fondamentali della sicurezza delle informazioni.

Confidenzialità: solo i soggetti autorizzati accedono alle informazioni (cifratura, controlli di accesso, classificazione, need-to-know). Integrità: i dati non sono alterati in modo non autorizzato o non rilevato (hash, firme digitali, controlli applicativi, log di modifica). Disponibilità: i servizi e i dati sono fruibili quando necessario (ridondanza, backup, anti-DDoS, manutenzione programmata, capacity).

Ogni controllo di sicurezza può essere letto rispetto a CIA. Esempio: TLS !' C e I del canale; cluster + backup !' D; firma digitale !' I e autenticità del documento; MFA !' protezione della C riducendo account takeover. Nella PA si aggiungono spesso autenticità, non ripudio e privacy (GDPR) come obiettivi collegati, senza sostituire la triade di base.

Apri quasi ogni risposta di sicurezza con CIA: orienta il valutatore e evita elenchi disordinati di tool. Schema: definisci le tre lettere in italiano, associa un controllo a ciascuna, fai un esempio PA (portale servizi, protocollo, posta). È la cornice che tiene insieme crittografia, attacchi e misure di igiene.

Glossario

CIA — Confidentiality, Integrity, Availability — Confidenzialità, Integrità, Disponibilità.

Non ripudio — Impossibilità per l'autore di negare di aver compiuto un'azione (es. firma qualificata).

In prova: Espandi l'acronimo in italiano e associa un controllo a ciascuna lettera.

Riferimenti: Fondamenti sicurezza informazioni

2. Crittografia simmetrica, asimmetrica e hash

Simmetrica = stessa chiave; asimmetrica = coppia pubblica/privata; hash = impronta non invertibile.

Crittografia simmetrica (AES e analoghi): stessa chiave per cifrare e decifrare; efficiente per grandi volumi di dati, ma pone il problema della distribuzione sicura delle chiavi. Asimmetrica (RSA, curve ellittiche): chiave pubblica per cifrare o verificare; chiave privata per decifrare o firmare. I protocolli reali (TLS) combinano le due (handshake asimmetrico + chiave di sessione simmetrica).

La firma digitale usa la chiave privata del firmatario; chiunque verifica con la pubblica. Per la confidenzialità verso un destinatario si cifra con la sua chiave pubblica (o si usa un canale ibrido). L'hash (SHA-256, ecc.) produce un'impronta a lunghezza fissa non invertibile: utile per integrità e per memorizzare password — ma solo con salt e KDF dedicati (bcrypt/scrypt/Argon2), non con hash «nudo» tipo SHA solo.

Schema d'esame da ripetere senza esitazioni: chiave privata !' firma (autenticità); chiave pubblica del destinatario !' cifra (confidenzialità). Password !' mai in chiaro, mai solo MD5/SHA, hash con salt + KDF. Domanda classica PAT: «Per autenticità firmo con...?» !' chiave privata.

Glossario

Salt — Valore casuale aggiunto alla password prima dell'hash per impedire rainbow table.

KDF — Key Derivation Function: deriva chiavi/impronte in modo computazionalmente costoso (es. per password).

Coppia di chiavi — Chiave pubblica (condivisibile) e chiave privata (segreta) della crittografia asimmetrica.

In prova: Domanda classica: «Per autenticità firmo con...?» !' chiave privata.

Riferimenti: CAD / eIDAS (firma) · Buone pratiche password hashing

3. Attacchi tipici

Phishing, ransomware, DDoS, SQL injection e XSS sono famiglie ricorrenti nelle prove e nella realtà PA.

Phishing: ingegneria sociale via email/messaggi/SMS per rubare credenziali o indurre azioni (bonifici, installazione malware); si mitiga con formazione, MFA, filtri antispam e verifica dei mittenti. Ransomware: cifra i dati e chiede riscatto; si mitiga con backup offline/immutabili, patching, least privilege, segmentazione e esercitazioni di restore. DDoS: saturazione di risorse di rete/servizio per negare disponibilità (colpisce la D della CIA).

SQL injection e XSS sono attacchi applicativi: il primo manipola query sul database; il secondo inietta script nel browser delle vittime (session hijacking, defacement). Difese: input validation, prepared statement, encoding in output, Content Security Policy, aggiornamenti framework e code review. Altri temi utili: credential stuffing, privilege escalation, attacchi alla supply chain.

In risposta elenca 4–5 attacchi con una riga di mitigazione ciascuno e, se possibile, abbinati a CIA (phishing!C, ransomware!C/I/D, DDoS!D, injection!C/I): qualità da assistente operativo, non da elenco memorizzato vuoto. Evita dettagli di exploit: conta il ragionamento difensivo.

Glossario

Phishing — Inganno per indurre a rivelare credenziali o eseguire azioni dannose.

Ransomware — Malware che cifra dati e chiede riscatto per il ripristino.

XSS — Cross-Site Scripting: iniezione di script malevoli nelle pagine viste dagli utenti.

In prova: Abbinati ogni attacco a CIA (phishing!C, ransomware!C/I/D, DDoS!D, injection!C/I).

Riferimenti: OWASP Top 10 · Buone pratiche cybersicurezza PA

4. MFA, least privilege, patching, backup

Controlli di igiene essenziali: autenticazione a più fattori, minimi privilegi, aggiornamenti e backup verificati.

MFA (Multi-Factor Authentication) combina almeno due fattori tra conoscenza (password), possesso (OTP, token, CIE) e inerenza (biometria): riduce drasticamente il rischio di password rubate o riusate. Least privilege: ogni utente e ogni processo ha solo i permessi necessari, per il tempo necessario (JIT ove possibile), evitando account admin «per comodità». Patching tempestivo chiude vulnerabilità note su SO, firmware, hypervisor e applicativi.

Backup: regola empirica 3-2-1 (tre copie, due tipi di supporto, una copia offsite); meglio se immutabili o offline contro ransomware. I backup vanno testati con restore periodici documentati: un backup non collaudato è un rischio nascosto che falsifica RTO/RPO. In cloud valgono le stesse logiche, con chiarezza su shared responsibility (cosa protegge il provider, cosa resta all'ente).

Quattro controlli = risposta completa a «misure minime di sicurezza» o «cosa faresti per mettere in sicurezza un servizio». Elenco d'oro: MFA + least privilege + patch + backup testato. Collega a misure AgID storiche e al quadro ACN senza inventare numeri di articolo non richiesti.

Glossario

MFA — Autenticazione a più fattori (es. password + OTP o CIE).

3-2-1 — Strategia di backup: 3 copie, 2 tipi di supporto, 1 copia offsite.

In prova: Elenco d'oro: MFA + least privilege + patch + backup testato.

Riferimenti: Misure minime di sicurezza ICT · Quadro ACN

5. Privacy by design e GDPR

Privacy by design/by default e misure tecniche organizzative adeguate sono doveri del titolare del trattamento.

Il Regolamento (UE) 2016/679 (GDPR) impone di progettare i sistemi proteggendo i dati personali fin dall'inizio (privacy by design) e con impostazioni predefinite restrittive (by default). Minimizzazione, limitazione delle finalità, cifratura, pseudonimizzazione, log di accesso, tempi di retention e diritti degli interessati (accesso, cancellazione, portabilità ove applicabile) sono esempi di misure tecniche e organizzative.

Nella PA il titolare del trattamento resta l'amministrazione; fornitori cloud/software agiscono spesso come responsabili del trattamento con contratto (art. 28 GDPR) e istruzioni documentate. Il DPO (Responsabile della protezione dei dati) supporta e sorveglia la conformità ma non «sostituisce» il titolare. In caso di data breach: notifica al Garante entro i termini e, se il rischio per gli interessati è elevato, comunicazione agli stessi.

Per l'assistente informatico: ogni nuovo applicativo implica valutazione di impatto (DPIA) ove richiesta, ruoli di accesso coerenti col least privilege, cifratura in transito (TLS) e a riposo ove adeguata, e cancellazione/anonimizzazione al termine della retention. In orale collega GDPR a misure concrete, non solo a principi astratti: la commissione valuta il passaggio dal «diritto» al «sistema».

Glossario

Privacy by design — Integrare la protezione dei dati nella progettazione di processi e sistemi sin dall'inizio.

Privacy by default — Impostazioni iniziali che limitano trattamento e accessibilità ai soli dati necessari.

DPO — Data Protection Officer / Responsabile della protezione dei dati.

In prova: Cita GDPR + by design/by default + esempio tecnico (minimizzazione, cifratura, log, retention).

Riferimenti: Regolamento (UE) 2016/679 (GDPR)

Ordinamento statutario PAT

Autonomia speciale della Provincia autonoma di Trento, leggi provinciali 2 e 3 del 2003, organi e rapporti con gli enti locali: telaio tipico dell'orale istituzionale.

Da ricordare

Apri con «autonomia speciale», cita L.P. 2 e 3/2003, collega organi !' sussidiarietà !' un esempio concreto di servizio (anche digitale) al cittadino.

1. Autonomia speciale

La PAT non è una Regione a statuto ordinario: lo Statuto speciale le attribuisce poteri legislativi e amministrativi più ampi e differenziati.

La Provincia autonoma di Trento rientra nel sistema delle autonomie speciali italiane. A differenza delle Regioni a statuto ordinario, lo Statuto speciale (norme costituzionali di rango speciale) le riconosce competenze legislative e amministrative più estese e, in molte materie, una capacità di organizzazione interna autonoma. Per l'esame non serve citare articolo per articolo lo Statuto: conta capire che l'ordinamento provinciale è «speciale» e che le leggi provinciali possono disciplinare ampi settori della vita pubblica locale.

L'autonomia si traduce in tre piani pratici: legislativo (leggi provinciali in materie attribuite), amministrativo (organizzazione degli uffici e dei servizi) e finanziario (risorse e programmazione proprie, nei limiti del quadro costituzionale e degli accordi con lo Stato). Per un Assistente informatico questo significa che piattaforme, regolamenti interni, piani digitali e regole di trasparenza si muovono spesso in un quadro provinciale, pur restando vincolati a norme nazionali e europee (CAD, GDPR, eIDAS, anticorruzione).

In orale conviene evitare toni «separatisti» o slogan: l'autonomia speciale non significa indifferenza al diritto nazionale, ma poteri differenziati entro la Repubblica. Una frase efficace: «La PAT ha autonomia legislativa e amministrativa speciale; organizza i propri servizi, anche digitali, nel rispetto dello Statuto, delle L.P. di organizzazione e dei vincoli nazionali/UE».

Glossario

Statuto speciale — Fonte costituzionale che attribuisce a Trento (e Bolzano) poteri differenziati rispetto alle Regioni ordinarie.

Autonomia legislativa — Potere di adottare leggi provinciali nelle materie attribuite dallo Statuto e dalle norme di attuazione.

In prova: Quiz e orale: «poteri diversi dalle Regioni ordinarie», non «assenza di Consiglio/Giunta» né «coincide con un Comune».

Riferimenti: Statuto speciale per il Trentino-Alto Adige/Südtirol · Programma orale bando Assistente informatico PAT

2. L.P. 2 e 3 del 5 marzo 2003

Le due leggi provinciali del 5 marzo 2003 sono il riferimento organizzativo citato dal bando: assetto istituzionale e organizzazione dell'autonomia.

Il bando richiama espressamente le leggi provinciali 5 marzo 2003, n. 2 e n. 3. Non sono norme su privacy, firme o penale informatico: disciplinano l'assetto istituzionale della Provincia e l'organizzazione dell'autonomia, cioè come si articolano organi, funzioni e rapporti con il territorio. In prova, se ti chiedono «di cosa parlano le L.P. 2 e 3/2003?», la risposta corretta è l'ordinamento/organizzazione della PAT, non il CAD o il GDPR.

Nella preparazione serve memorizzare la data e i numeri (5 marzo 2003, n. 2 e n. 3) e il ruolo: telaio dell'organizzazione provinciale post-riforma dell'autonomia. La L.P. 2 riguarda tipicamente l'assetto istituzionale; la L.P. 3 l'organizzazione dell'autonomia e i rapporti con gli enti locali. Non è necessario riprodurre l'intero testo: conta saperle collocare come fonti provinciali di organizzazione.

Esempio da Assistente IT: quando l'ente progetta un servizio digitale «provinciale» (portale, anagrafe, protocollo, sistemi per Comunità o Comuni), lo fa dentro questo quadro organizzativo: chi decide, chi eroga, chi coordina. Le L.P. 2 e 3 spiegano il «chi» istituzionale; CAD e linee guida AgID spiegano il «come» digitale.

Glossario

L.P. 5 marzo 2003, n. 2 — Legge provinciale sull'assetto istituzionale della PAT, richiamata nel programma d'esame.

L.P. 5 marzo 2003, n. 3 — Legge provinciale sull'organizzazione dell'autonomia e sui rapporti con gli enti locali.

In prova: Schema risposta: citazione delle due L.P. l'oggetto (assetto/organizzazione) !' collegamento a organi o enti locali in una frase.

Riferimenti: L.P. 5 marzo 2003, n. 2 · L.P. 5 marzo 2003, n. 3

3. Organi e rapporti con gli enti locali

Consiglio, Presidente e Giunta sono gli organi di vertice; sul territorio contano Comuni e Comunità di valle.

Gli organi fondamentali della Provincia sono il Consiglio provinciale (organo legislativo e di indirizzo politico), il Presidente della Provincia (rappresentanza e direzione dell'esecutivo) e la Giunta provinciale (organo esecutivo collegiale). In orale basta una descrizione funzionale: il Consiglio adotta le leggi e gli atti di indirizzo; Presidente e Giunta governano l'amministrazione e attuano il programma. Non serve un organigramma completo dei dipartimenti.

L'amministrazione provinciale si articola in strutture (dipartimenti, servizi, uffici) cui fanno capo anche le funzioni IT: help desk, gestione reti, applicazioni, sicurezza operativa. L'assistente informatico lavora in questa macchina amministrativa, non «fuori» dall'ordinamento: le decisioni su strumenti, fornitori e accessi seguono gerarchia, regolamenti e piani dell'ente.

I rapporti con gli enti locali — Comuni e Comunità di valle — sono parte integrante dell'ordinamento trentino. Molti servizi al cittadino nascono da collaborazione o riparto di funzioni: sportelli, anagrafiche, sistemi informativi condivisi, supporto tecnologico. Un esempio concreto: un applicativo gestito a livello provinciale usato dai Comuni, oppure infrastrutture e standard comuni per l'interoperabilità territoriale.

Glossario

Consiglio provinciale — Organo legislativo e di indirizzo della PAT.

Giunta provinciale — Organo esecutivo collegiale che attua l'indirizzo politico-amministrativo.

Comunità di valle — Enti intermedi del territorio trentino che collaborano/ripartiscono funzioni con Provincia e Comuni.

In prova: Elenca i tre organi in una frase, poi aggiungi «rapporti con Comuni e Comunità» e un esempio di servizio condiviso.

4. Competenze e sussidiarietà

Le competenze provinciali e locali si ripartiscono secondo specialità e sussidiarietà: il livello più vicino al cittadino interviene quando è adeguato.

Oltre agli organi, l'orale può chiedere il riparto di funzioni: materie di competenza provinciale (proprie o differenziate rispetto allo Stato) e funzioni esercitate da Comuni e Comunità. Non è richiesta una mappa enciclopedica: conta il principio che l'autonomia speciale attribuisce alla PAT ampi spazi di disciplina e che l'organizzazione territoriale distribuisce i compiti sul territorio.

Il principio di sussidiarietà orienta l'allocazione delle funzioni: si privilegia il livello di governo più vicino ai cittadini quando è in grado di svolgere efficacemente il compito; il livello superiore interviene per esigenze di unitarietà, equità o capacità. In Trentino questo principio si collega al ruolo delle Comunità di valle e dei Comuni rispetto alla Provincia.

Per il profilo IT la sussidiarietà ha un volto operativo: chi ospita il dato, chi gestisce l'applicativo, chi autorizza gli accessi, chi pubblica in trasparenza. Un sistema «centrale» provinciale può supportare enti locali senza sostituirne le responsabilità amministrative; viceversa, soluzioni locali devono restare interoperabili e coerenti con standard e obblighi dell'ente.

Glossario

Sussidiarietà — Principio per cui le funzioni sono esercitate dal livello più vicino al cittadino, compatibilmente con efficacia e unitarietà.

Competenza propria — Ambito in cui la Provincia legifera e amministra in via autonoma, nei limiti dello Statuto e delle norme di attuazione.

In prova: Collega sussidiarietà !' enti locali !' esempio IT (piattaforma provinciale a supporto dei Comuni).

5. Come rispondere all'orale

Meglio una catena logica breve che un elenco nozionistico: autonomia !' L.P. !' organi !' servizio al cittadino.

Struttura consigliata in 60–90 secondi: (1) «La PAT gode di autonomia speciale rispetto alle Regioni ordinarie»; (2) «Le L.P. 2 e 3 del 5 marzo 2003 disciplinano assetto istituzionale e organizzazione dell'autonomia»; (3) «Organi di vertice: Consiglio, Presidente, Giunta; sul territorio Comuni e Comunità secondo sussidiarietà»; (4) chiusura con un esempio concreto.

Esempio di chiusura IT: «Questa organizzazione consente di progettare servizi digitali provinciali — ad esempio portali o sistemi condivisi con i Comuni — rispettando trasparenza, anticorruzione e regole nazionali come il CAD». Così dimostri di non ripetere definizioni a vuoto, ma di collegare diritto e lavoro quotidiano.

Errori da evitare: confondere L.P. 2/3 con GDPR o eIDAS; dire che la PAT «non ha poteri legislativi»; elencare dieci uffici senza spiegare il ruolo degli organi; dimenticare enti locali e sussidiarietà. Se la commissione approfondisce, riparti dal principio (autonomia/sussidiarietà) e scendi all'esempio, non al contrario.

In prova: Memorizza la «scaletta a quattro passi» e un solo esempio IT: vale più di dieci definizioni sparse.
Riferimenti: Programma orale bando Assistente informatico PAT 2026

Anticorruzione e trasparenza (PIAO)

PIAO provinciale, allegato anticorruzione/trasparenza, ruolo dell'RPCT, misure tipiche, accessi e conflitti di interesse — con esempi per chi lavora sui sistemi.

Da ricordare

Schema: PIAO !' allegato anticorruzione/trasparenza !' RPCT !' misura concreta + esempio IT (accessi, log, fornitori, pubblicazione dati).

1. PIAO e allegato anticorruzione/trasparenza

Il PIAO integra la pianificazione dell'ente; il Piano per la prevenzione della corruzione e per la trasparenza ne è allegato/sezione sostanziale.

Il PIAO (Piano Integrato di Attività e Organizzazione) è lo strumento con cui molte amministrazioni, inclusa la PAT nel quadro richiamato dal bando, riuniscono programmazione di attività, organizzazione, performance e — in allegato o sezione dedicata — prevenzione della corruzione e trasparenza. Non sostituisce il CAD né il contratto collettivo: è un piano di governance interna.

Il «Piano anticorruzione e trasparenza» della Provincia va quindi presentato come parte del PIAO: definisce analisi dei rischi, misure preventive, obblighi di pubblicazione, monitoraggio e responsabilità. In quiz, la risposta corretta è che tale piano è allegato/integrato nel PIAO, non che lo adotta AgID o che coincide con il CCPL.

Per l'assistente informatico il PIAO/allegato conta perché molte misure toccano i sistemi: censimento delle banche dati, regole di accesso, tracciatura, pubblicazione di documenti e dataset, gestione delle segnalazioni. Conoscere l'esistenza del piano e il suo collegamento al PIAO è il minimo per l'orale; saper fare un esempio operativo è il valore aggiunto.

Glossario

PIAO — Piano Integrato di Attività e Organizzazione dell'ente.

PTPCT / sezione anticorruzione-trasparenza — Documento (allegato o sezione del PIAO) che programma misure anticorruzione e obblighi di trasparenza.

In prova: Prima frase: «Il piano anticorruzione/trasparenza è allegato al PIAO provinciale»; poi RPCT e una misura.

Riferimenti: Quadro nazionale sul PIAO (D.L. 80/2021 e atti successivi) · PIAO / allegato anticorruzione e trasparenza PAT

2. RPCT — Responsabile della prevenzione della corruzione e della trasparenza

L'RPCT coordina il sistema di prevenzione e trasparenza; non va confuso con l'RTD.

L'RPCT (Responsabile della Prevenzione della Corruzione e della Trasparenza) è la figura di riferimento per predisporre/aggiornare le misure, vigilare sull'attuazione, promuovere la trasparenza e gestire i flussi legati a segnalazioni e pubblicazioni, secondo il modello nazionale adattato all'ente. Non «sostituisce» dirigenti e dipendenti: ciascuno resta responsabile dei propri adempimenti.

Distinzione d'esame: RPCT " RTD. L'RTD (Responsabile per la Transizione Digitale) guida digitalizzazione, interoperabilità e innovazione dei servizi; l'RPCT cura anticorruzione e trasparenza. Possono collaborare (es. pubblicazione dati, sicurezza degli accessi, registro trattamenti collegato a rischi), ma i mandati restano distinti. Non sono la stessa persona «per legge».

Esempio IT: se emerge un uso anomalo di utenze privilegiate su un gestionale di gare, l'assistente segnala al responsabile gerarchico/strutture competenti; l'RPCT interviene sul piano delle misure di prevenzione e degli obblighi di trasparenza/controllo, mentre eventuali aspetti tecnici di hardening restano al team IT/sicurezza. In orale basta mostrare di conoscere il canale e la differenza di ruoli.

Glossario

RPCT — Responsabile della Prevenzione della Corruzione e della Trasparenza.

RTD — Responsabile per la Transizione Digitale (CAD): digitalizzazione dell'ente, non anticorruzione.

In prova: Frase pronto-uso: «RPCT anticorruzione/trasparenza; RTD digitalizzazione — mandati diversi, possibile collaborazione».

3. Misure tipiche: mappatura, rotazione, whistleblowing, formazione

Le misure preventive tipiche vanno spiegate con esempi concreti, soprattutto su accessi e processi IT.

La mappatura dei processi e dei rischi individua dove possono annidarsi corruzione, abuso d'ufficio o cattiva gestione (appalti IT, gestione utenze, affidamenti, liquidazioni, accesso a banche dati sensibili). Per chi lavora sui sistemi, «mappare» significa anche sapere quali applicativi toccano procedure a rischio e quali privilegi esistono.

La rotazione del personale (ove possibile) riduce la cristallizzazione di poteri su pratiche sensibili; in ambito IT spesso si traduce in segregazione delle funzioni, rotazione su incarichi di amministrazione di sistemi critici, dual control su operazioni privilegiate, revisioni periodiche dei privilegi. Dove la rotazione classica è difficile (skill rare), si rafforzano controlli compensativi: log, approvazioni a quattro occhi, least privilege.

Whistleblowing: canali di segnalazione di illeciti con tutele per il segnalante (riservatezza, divieto di ritorsioni), oggi anche alla luce della disciplina nazionale di recepimento UE. Formazione e monitoraggio chiudono il ciclo: il dipendente deve conoscere le misure; l'ente verifica l'attuazione. Esempio orale: «Su un applicativo di protocollo, misura = profili minimi, log degli accessi, formazione sul divieto di consultazioni personali, canale di segnalazione se si sospetta abuso».

Glossario

Mappatura dei rischi — Analisi dei processi dell'ente per individuare aree e eventi di rischio corruttivo.

Whistleblowing — Segnalazione di illeciti tramite canali protetti, con tutela del segnalante.

Least privilege — Principio per cui a ciascun utente si assegnano solo i permessi necessari al compito.

In prova: Elenca almeno tre misure e legane una al lavoro IT (accessi, log, fornitori).

Riferimenti: L. 190/2012 e aggiornamenti · Disciplina whistleblowing (D.Lgs. 24/2023)

4. Trasparenza e i tre accessi

Obblighi di pubblicazione e tre vie di accesso: documentale (L. 241), civico semplice, civico generalizzato (FOIA).

La trasparenza impone di pubblicare in «Amministrazione trasparente» (o sezioni equivalenti) atti, dati e informazioni previsti dalla legge: organizzazione, bandi, pagamenti, incarichi, ecc. La pubblicazione riduce asimmetrie informative e supporta il controllo sociale. L'IT spesso abilita CMS, open data e flussi automatici di pubblicazione: errori tecnici possono diventare inadempienze di trasparenza.

Accesso documentale (L. 241/1990): chi ha un interesse diretto, concreto e attuale può chiedere documenti del procedimento che lo riguarda, con i limiti di legge (es. segreti, privacy di terzi). Non è un diritto «di chiunque» a tutto il fascicolo pubblico.

Accesso civico semplice: serve a ottenere la pubblicazione di documenti/dati che l'amministrazione avrebbe già dovuto pubblicare e non ha pubblicato. Accesso civico generalizzato (FOIA, D.Lgs. 33/2013 come novellato): chiunque può chiedere dati e documenti ulteriori rispetto a quelli oggetto di pubblicazione obbligatoria, salvo limiti (sicurezza, segreto, protezione dati, ecc.). In orale distingue sempre i tre: interesse qualificato (241) vs obbligo di pubblicazione inadempito (civico semplice) vs accesso generalizzato con limiti (FOIA).

Glossario

Accesso documentale — Accesso L. 241/1990 fondato su interesse diretto, concreto e attuale.

Accesso civico semplice — Richiesta di pubblicazione di ciò che doveva già essere pubblicato.

FOIA / accesso civico generalizzato — Accesso di chiunque a dati/documenti ulteriori, entro i limiti di legge.

In prova: Tabella mentale a tre colonne; una frase per tipo. Non dire che il FOIA «cancella» la 241 o le pubblicazioni.

Riferimenti: L. 241/1990 · D.Lgs. 33/2013 e s.m.i.

5. Conflitto di interessi, inconferibilità e incompatibilità

Il conflitto di interessi e i regimi di inconferibilità/incompatibilità proteggono imparzialità e credibilità dell'azione amministrativa.

Esiste conflitto di interessi quando un interesse privato (proprio, familiare, di terzi legati) può interferire con il dovere di imparzialità. Va dichiarato e gestito: astensione, segnalazione al responsabile, riassegnazione della pratica. In ambito IT esempi tipici: partecipare alla valutazione di un software venduto da un parente; amministrare un sistema e insieme gestire il contratto con il fornitore senza controlli; usare informazioni riservate di gara per favorire un ex collega consulente.

Inconferibilità e incompatibilità riguardano soprattutto incarichi dirigenziali e di vertice (e fattispecie normate): certi precedenti incarichi privati o politici possono rendere un incarico pubblico inconferibile (non attribuibile) o incompatibile (non cumulabile). Anche se l'assistente non è dirigente, in orale può essere chiesto il concetto: tutela preventiva dell'imparzialità prima e durante l'incarico.

Collegamento operativo: registri delle dichiarazioni, controlli a campione, segregazione tra chi progetta requisiti di gara IT e chi ha rapporti personali con fornitori, tracciamento delle utenze. Se dubbi, non «risolvi da solo»: dichiara e chiedi indicazioni al responsabile. È una risposta da commissione: mostra prudenza e conoscenza delle procedure.

Glossario

Conflitto di interessi — Situazione in cui un interesse privato può compromettere l'imparzialità del dipendente/incaricato.

Inconferibilità — Preclusione ad assumere un incarico pubblico in presenza di determinate condizioni previste dalla legge.

Incompatibilità — Divieto di cumulare certi incarichi o attività con l'incarico pubblico rivestito.

In prova: Definisci il conflitto in una riga, fai un esempio IT, chiudi con dichiarazione/astensione.

Riferimenti: D.Lgs. 39/2013 · Codice di comportamento PAT / misure PIAO

Codice di comportamento e disciplinare

Delibera G.P. 1514/2024, elementi di CCPL, responsabilità disciplinare, codice anti-molestie e doveri specifici per chi gestisce sistemi e dati.

Da ricordare

Collega dovere di comportamento !' possibile illecito disciplinare !' garanzie del procedimento. Se IT: riservatezza, uso degli strumenti, segnalazione incidenti.

1. Codice di comportamento (delibera G.P. 1514/2024)

Il codice provinciale precisa doveri di imparzialità, regali, rapporti con il pubblico, uso di beni e informazioni, anche sui social.

La delibera della Giunta provinciale n. 1514/2024 adotta/aggiorna il codice di comportamento dei dipendenti provinciali, in coerenza con i principi del codice nazionale (D.P.R. 62/2013 e s.m.i.) e con le specificità dell'ente. Non è un regolamento tecnico IT: è il catalogo dei doveri quotidiani di correttezza, lealtà, imparzialità e buon andamento.

Temi tipici da ricordare: regali e altre utilità (di regola solo quelli d'uso di modico valore entro le soglie/regole interne; un regalo non modico da un fornitore IT si rifiuta o si attiva la procedura prevista, non si «divide in ufficio»); rapporti con il pubblico (cortesia, completezza delle informazioni, pari trattamento); uso di beni e strumentazioni dell'ente per finalità di servizio; tutela delle informazioni di cui si viene a conoscenza per ragioni d'ufficio.

I social e la comunicazione online rientrano nel perimetro: il dipendente non deve ledere il prestigio dell'amministrazione, rivelare dati riservati o assumere comportamenti che confondano opinioni personali e posizione istituzionale quando parla «in quanto dipendente». Esempio: pubblicare screenshot di una pratica o di una console di amministrazione è tipicamente vietato, anche se «per scherzo».

Glossario

Delibera G.P. 1514/2024 — Atto della Giunta provinciale che disciplina il codice di comportamento dei dipendenti PAT richiamato dal bando.

Modico valore — Soglia/uso consentito per regali di cortesia entro i limiti del codice; oltre si rifiuta o si segue la procedura.

In prova: Cita la delibera 1514/2024 e tocca almeno regali, pubblico, beni/informazioni, social.

Riferimenti: Delibera G.P. n. 1514/2024 · D.P.R. 62/2013 e s.m.i. (codice nazionale)

2. CCPL essenziale

Il contratto collettivo provinciale di lavoro inquadra il rapporto di lavoro: diritti, doveri, orario, istituti e relazioni sindacali — a livello essenziale per l'orale.

Il CCPL (Contratto Collettivo Provinciale di Lavoro) del personale provinciale disciplina gli istituti fondamentali del rapporto di lavoro: inquadramento, mansioni, orario, ferie e permessi, trattamento economico nei limiti del contratto, diritti sindacali, procedimenti collegati al rapporto di lavoro. Per l'esame da Assistente non serve conoscere tabelle retributive: serve sapere che esiste un telaio contrattuale che affianca legge e codice di comportamento.

Rapporto tra fonti: la legge e il codice di comportamento fissano doveri di condotta e imparzialità; il CCPL regola il rapporto di lavoro e, insieme al codice disciplinare, le conseguenze sul piano disciplinare e organizzativo. Una violazione del codice di comportamento può rilevare disciplinarmente secondo le procedure previste.

Esempio pratico: uso improprio dell'orario di lavoro per attività personali sui sistemi dell'ente, o rifiuto ingiustificato di rispettare procedure di sicurezza previste dall'amministrazione, possono toccare insieme dovere di diligenza (contratto) e doveri di comportamento (codice). In orale, una frase sul CCPL come «fonte del rapporto di lavoro provinciale» basta se poi colleghi al disciplinare.

Glossario

CCPL — Contratto Collettivo Provinciale di Lavoro del personale della PAT.

Inquadramento — Collocazione del dipendente in area/profilo professionale secondo il contratto.

In prova: Non entrare in dettagli retributivi: definisci il CCPL e collegalo a doveri + procedimento disciplinare.

3. Responsabilità disciplinare

Tipicità delle sanzioni, contraddittorio e proporzionalità sono le tre parole-chiave del procedimento disciplinare.

La responsabilità disciplinare nasce dalla violazione di doveri di servizio previsti da legge, contratto e codice di comportamento. Le sanzioni devono essere tipiche: cioè previste dall'ordinamento (richiamo, censura, multa, sospensione, licenziamento, ecc. secondo i casi), non inventate dal responsabile del procedimento. Serve contestazione degli addebiti in modo chiaro e tempestivo.

Il contraddittorio è garanzia essenziale: il dipendente deve poter conoscere gli addebiti, presentare difese, produrre documenti, farsi assistere. Non esiste «sanzione automatica senza difesa». La proporzionalità impone di graduare la sanzione alla gravità del fatto, alle circostanze, all'eventuale recidiva e all'intensità del danno o del pericolo per l'ente e i cittadini.

Esempio IT: la prima condivisione colposa di una password in chat interna non confidenziale non si tratta come un licenziamento «automatico» senza istruttoria; al tempo stesso, l'esfiltrazione dolosa di dati o l'abuso reiterato di privilegi può giustificare provvedimenti gravi. In orale insiste su: tipicità !' contraddittorio !' proporzionalità.

Glossario

Tipicità — Le sanzioni e le fattispecie rilevanti devono essere previste dall'ordinamento disciplinare/contrattuale.

Contraddittorio — Diritto del dipendente di difendersi rispetto agli addebiti contestati.

Proporzionalità — Adeguatezza della sanzione alla gravità del fatto e alle circostanze.

In prova: Se il quiz parla di procedimento disciplinare, cerca «contraddittorio e proporzionalità».

4. Codice di condotta contro le molestie

Prevenzione, emersione, tutela della persona segnalante e divieto di ritorsioni: clima organizzativo e dignità della persona.

Il codice di condotta contro le molestie (richiamato dal programma d'esame insieme al codice di comportamento) mira a prevenire comportamenti lesivi della dignità della persona — molestie sessuali, mobbing, discriminazioni — e a favorire segnalazione e intervento dell'ente. Non è un tema «extra»: fa parte dei doveri di ambiente di lavoro sicuro e rispettoso.

Il dipendente deve conoscere i canali di segnalazione previsti, mantenere la riservatezza sulle informazioni di cui viene a conoscenza, collaborare alle verifiche e astenersi da ritorsioni o secondary victimization verso chi segnala o testimonia. Anche chi non è vittima ha doveri di non partecipare a climates ostili e di non minimizzare fatti rilevanti.

In un ufficio tecnico o CED il rispetto del codice si traduce in professionalità quotidiana: linguaggio, scherzi, chat di gruppo, gestione dei turni e dei carichi. La competenza tecnica non giustifica comportamenti lesivi. In orale: finalità (prevenzione/tutela) !' canali !' riservatezza !' no ritorsioni.

Glossario

Molestia — Comportamento indesiderato che lede dignità, libertà o serenità della persona sul lavoro.

Divieto di ritorsioni — Protezione di chi segnala o collabora alle verifiche da misure punitive o discriminatorie.

In prova: Cinque parole: prevenzione, canali, tutela, riservatezza, no ritorsioni.

5. Doveri IT: riservatezza, strumenti, incidenti

Per l'assistente informatico i doveri di comportamento si concentrano su dati, credenziali, uso degli strumenti e segnalazione degli incidenti.

Riservatezza: chi amministra sistemi vede spesso dati personali, sanitari, tributari, contenuti di ticket e configurazioni di sicurezza. Vale il divieto di consultazioni personali («curiosare» pratiche di conoscenti), di estrazioni non autorizzate, di condividere credenziali o screenshot sensibili. Le password di dominio in chat pubblica o in ticket aperti violano tipicamente riservatezza e uso corretto degli strumenti.

Uso degli strumenti: PC, server, cloud, caselle di posta, VPN e account di amministrazione sono beni dell'ente. Servono all'attività di servizio; installazioni abusive, mining, navigazione illecita, bypass dei controlli di sicurezza o uso di utenze condivise «per comodità» espongono a rischio disciplinare e di sicurezza. Least privilege e tracciabilità non sono solo buone pratiche tecniche: sono anche adempimenti di comportamento.

Incidenti e vulnerabilità: sospetto phishing, ransomware, perdita di device, accesso anomalo, errore che espone dati vanno segnalati subito ai canali previsti (help desk/security/responsabile), senza nascondere l'accaduto e senza avviare «rimedi fai-da-te» che cancellano le prove. In orale puoi chiudere così: «Riservatezza dei dati, uso corretto degli strumenti, segnalazione tempestiva degli incidenti: è il nucleo comportamentale del profilo IT».

Glossario

Utenza privilegiata — Account con elevati poteri di amministrazione; richiede tutele rafforzate e divieto di condivisione.

Incidente di sicurezza — Evento che compromette o minaccia riservatezza, integrità o disponibilità di sistemi/dati; va segnalato.

In prova: Porta sempre un esempio concreto (password, log, phishing). Collega codice di comportamento !' rischio disciplinare !' procedura di segnalazione.

Riferimenti: Codice di comportamento PAT (delibera G.P. 1514/2024) · Policy interne su accettabile use e incident response (ove adottate)